THIRSTY'S CODEX

STANDARDS EDITION

VOLUME VII / 07 OF 20

CYBERSECURITY THROUGH PRIVACY ENGINEERING

Lifecycle Sections 189-218

NO PROOF, NO CLAIM

CONTINUOUS MASTER FOLIO / SOURCE-PRESERVING EDITION

Edition Statement

THIRSTY'S CODEX / STANDARDS EDITION / SOURCE-PRESERVING SET

This volume is one part of a continuous 20-volume edition. Canonical lifecycle section numbers remain stable across the set; no volume restarts or renumbers them.

The visual treatment has been rebuilt as a unified standards library: coordinated covers, volume architecture, source dividers, running headers, continuous master folios, local page numbers, and source-identity marks.

The source corpus remains authoritative over the presentation layer. Status terms are preserved exactly. CONTENT-COMPLETE does not silently become source-reconciled, hostile-reviewed, owner-accepted, ratified, or published.

Every registered source witness is identified by path, byte count, and SHA-256 digest. The complete source archive is preserved as an embedded attachment in Volume XX, while the two supplied foundational PDFs are preserved as attachments in Volume I.

CONTINUITY RULE

Read the master folio and canonical section sequence as one uninterrupted work. Each succeeding volume begins where the preceding volume ends.

Standards Edition Set Map

VOLUME I
Foundations and Governance
Doctrine, prompts, front matter, shared governance, roles, and output contracts

VOLUME II
Research, Strategy, and Risk
Lifecycle Sections 001-018

VOLUME III
Requirements through Hardware Architecture
Lifecycle Sections 019-060

VOLUME IV
Electrical Engineering through User Validation
Lifecycle Sections 061-106

VOLUME V
Software Systems through Smart Contracts
Lifecycle Sections 107-150

VOLUME VI
Data, Intelligence, and Human Oversight
Lifecycle Sections 151-188

VOLUME VII
Cybersecurity through Privacy Engineering
Lifecycle Sections 189-218

VOLUME VIII
Law, Assurance, and Validation
Lifecycle Sections 219-257

VOLUME IX
Configuration through Delivery Infrastructure
Lifecycle Sections 258-300

VOLUME X
Production Operations and Command
Lifecycle Sections 301-332

VOLUME XI
Support, Enterprise, and Roadmaps
Lifecycle Sections 333-373

VOLUME XII
Maintenance, Decommissioning, and Retirement
Lifecycle Sections 374-406

VOLUME XIII
Reference Registers and Working Documentation
Indexes, cross-references, source registers, checkpoints, and operational guides

VOLUME XIV
Standards Source Library
Preserved standards, command editions, blueprints, and source artifacts

VOLUME XV
Canonical Authority and Assurance
Authority, constitutions, policies, schemas, provenance, evaluation, and verifica...

VOLUME XVI
Applied Corpus and V3Q
Agent-output corpus, V3Q implementation, fixtures, tests, and governed examples

VOLUME XVII
Training Views and Indexes
Continuous-pretraining, evaluation, retrieval, and training views with canonical ...

VOLUME XVIII
Agents and Owner Command Standards
Agents 101 and Owner's Cockpit source-standard facsimiles

VOLUME XIX
Static Analysis and Tooling Evidence
Codacy configuration, rulesets, analysis logs, and repository tooling

Volume Contents

PAGE 1 OF 1

268 Section 189 - Cybersecurity Engineering 5
269 Section 190 - Application Security 9
270 Section 191 - Product Security 13
271 Section 192 - Platform Security 17
272 Section 193 - Infrastructure Security 21
273 Section 194 - Cloud Security 25
274 Section 195 - Network Security 29
275 Section 196 - Endpoint Security 33
276 Section 197 - Mobile Security 37
277 Section 198 - Embedded Security 42
278 Section 199 - Hardware Security 47
279 Section 200 - Identity And Access Management 51
280 Section 201 - Authentication Engineering 55
281 Section 202 - Authorization Engineering 59
282 Section 203 - Cryptography 63
283 Section 204 - Key Management 67
284 Section 205 - Secrets Management 71
285 Section 206 - Security Operations 75
286 Section 207 - Threat Intelligence 79
287 Section 208 - Threat Modeling 83
288 Section 209 - Vulnerability Management 87
289 Section 210 - Penetration Testing 91
290 Section 211 - Red Teaming 95
291 Section 212 - Blue Teaming 99
292 Section 213 - Digital Forensics 103
293 Section 214 - Incident Response 107
294 Section 215 - Fraud Prevention 111
295 Section 216 - Abuse Prevention 115
296 Section 217 - Trust And Safety 119
297 Section 218 - Privacy Engineering 123

189

SECTION 189 - CYBERSECURITY ENGINEERING

CODEX/03_SECTIONS/189_CYBERSECURITY_ENGINEERING.txt

SHA-256 e95b4f751730b15463f04db4b1f68bfe715e09c90eaf2067e23c3b130eaed244

8,168 BYTES / PRESERVED SOURCE IDENTITY

SECTION 189 — Cybersecurity Engineering

STATUS: CONTENT-COMPLETE

PURPOSE

Establish and maintain engineered protections for confidentiality, integrity, availability, authenticity, accountability, privacy, safety, and user control across the system lifecycle. Cybersecurity Engineering converts approved risk, threat, governance, architecture, and operational requirements into defensible controls and measurable residual risk.

REQUIRED OUTCOME

- A bounded cybersecurity scope, threat model, control architecture, owners, authorities, trust boundaries, and lifecycle states.
- Security requirements allocated to people, processes, applications, platforms, infrastructure, data, interfaces, suppliers, and operations.
- Tested prevention, detection, response, recovery, evidence, and continuous-improvement paths with explicit limitations.

WHY THIS MATTERS

Security failures can harm people, expose records, corrupt decisions, interrupt essential services, and destroy evidence. Security is a system property requiring coordinated engineering, operation, governance, and human judgment rather than a scan result or product feature.

APPLICABILITY

Applies when systems, data, identities, devices, facilities, suppliers, interfaces, models, or operations face unauthorized access, misuse, disruption, manipulation, disclosure, or loss. It applies proportionally to consequence, exposure, and recovery dependence.

NON-APPLICABILITY CONDITIONS

May be recorded only when an approved current security architecture covers the exact scope, version, environment, data, threat conditions, and change with no material effect. Purely descriptive or synthetic work may remain proposed, but cannot claim security acceptance.

PREREQUISITES AND DEPENDENCIES

Sections 018, 019, 020, 021-048, and 050-052 provide risk, requirements, system, architecture, governance, safety, reliability, and resilience context. Owners for assets, threats, controls, exceptions, incidents, evidence, and acceptance must be named.

REQUIRED INPUTS

Asset inventory, data classifications, trust boundaries, users, operators, dependencies, threat intelligence, risk appetite, control objectives, policies, architecture, vulnerabilities, incidents, recovery targets, and legal or contractual obligations.

HUMAN RESPONSIBILITIES AND AUTHORITY

The human authority defines protected outcomes, accepts residual risk, approves exceptions, assigns owners, authorizes testing, and decides containment, disclosure, recovery, and acceptance. Security engineers advise and implement within that authority.

AI RESPONSIBILITIES AND BOUNDARIES

AI may inventory, correlate, model threats, draft controls, analyze telemetry, and propose tests. It must preserve provenance and uncertainty, cannot infer permission or approve risk, cannot expose secrets, and must escalate ambiguous authority, active harm, or incomplete evidence.

APPLICABLE EXISTING AGENT ROLES

Architect, Analyst, Researcher, Security Auditor, Governance Reviewer, Observer, Critic, Red Team, Implementer, Tester, Verifier, Documentation Writer, Memory Curator, Coordinator, Planner, and Optimizer, selected proportionally to consequence and with independent verification where needed.

REQUIRED ACTIVITIES

1. Establish assets, protected outcomes, scope, owners, environments, trust boundaries, and assumptions.
2. Identify threats, abuse cases, vulnerabilities, dependencies, attack paths, and likely impact.
3. Derive, allocate, prioritize, and version security requirements and control objectives.
4. Design prevention, identity, authorization, hardening, monitoring, detection, response, recovery, and evidence controls.
5. Assess suppliers, changes, models, data, secrets, configuration, and common failure domains.
6. Test normal, adversarial, degraded, recovery, and evidence-preservation behavior.
7. Baseline residual risk, dissent, exceptions, invalidation conditions, and handoff obligations.

HUMAN-AI INTERACTION REQUIREMENTS

The human can inspect what is observed, inferred, proposed, implemented, tested, verified, and accepted. AI recommendations affecting access, disclosure, safety, privacy, continuity, or external communication require human review, visible evidence, alternatives, and a non-AI fallback. No conversational path bypasses identity, policy, audit, or incident controls.

ARCHITECTURE AND SYSTEM IMPLICATIONS

Represent assets, threats, controls, requirements, decisions, identities, events, findings, evidence, exceptions, incidents, and risk as versioned attributable records. Enforce controls at boundaries, separate prevention from detection, preserve defense in depth, and make safe halt, isolation, compensation, restoration, and evidence capture independently available.

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show security baseline, scope, asset criticality, active threats, control state, evidence freshness, findings, exceptions, residual risk, and available actions. Permit authorized approve, deny, isolate, revoke, contain, restore, disclose, reopen, and retire actions; show actor, authority, impact, and required approval.

REQUIRED OUTPUTS AND ARTIFACTS

Security charter, asset and trust-boundary inventory, threat model, requirements and control matrix, risk register, architecture decisions, test plans and results, exception records, monitoring and response design, recovery plan, acceptance record, and continuity handoff.

EVIDENCE REQUIREMENTS

Claims identify asset, version, environment, threat, method, scope, time, evidence source, owner, result, uncertainty, and limitation. Scans, benchmarks, attestations, and clean tests prove only their bounded claim. Failed, stale, missing, or contradictory evidence constrains status.

VERIFICATION AND ACCEPTANCE TESTS

Verify traceability from protected outcome to threat, requirement, control, implementation, telemetry, test, incident, and recovery. Exercise unauthorized access, tampering, denial, disclosure, dependency loss, key loss, stale telemetry, incident escalation, restore, and evidence replay. Independently reproduce material claims.

FAILURE STATES AND ANTI-PATTERNS

Treating a scan, certificate, firewall, or green dashboard as total security; unowned assets; security by obscurity; unlogged privileged access; shared secrets; missing recovery; ignoring suppliers and humans; optimizing availability or convenience by weakening control; and allowing AI to suppress findings or act beyond authority.

RECOVERY AND RECONSIDERATION

Contain, isolate, preserve volatile and durable evidence, revoke affected authority, communicate through approved channels, and record the decision chain. Recover from known-good artifacts or approved compensation, validate downstream impact, reassess residual risk, and reopen when threat, scope, architecture, data, or evidence changes.

COMPLETION CRITERIA

Scope, assets, threats, owners, controls, evidence, testing, residual risk, exceptions, recovery, and acceptance are explicit. Normal and hostile paths are tested, unresolved gaps constrain status, and the result remains CONTENT-COMPLETE pending source reconciliation, hostile review, and owner acceptance.

HANDOFF AND CONTINUITY REQUIREMENTS

Preserve baseline IDs, decisions, evidence, dissent, findings, exceptions, incidents, and next safe action. Hand off to Application, Platform, Infrastructure, Cloud, Network, Identity, Privacy, Governance, Compliance, Security Operations, Incident Response, Testing, Operations, and Retirement sections. Record reopening triggers.

RELATED CODEX SECTIONS

018 Risk Management; 019 Requirements Engineering; 020 Systems Engineering; 021-060 architecture sections; 190-218 security and privacy sections; 246 Security Testing; 270 DevSecOps; 301-330 operations and recovery; 405-406 lifecycle governance and retirement.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

Based on the Canonical Section Contract, shared governance, Sections 018-188, and the security and lifecycle roadmap. Supplied material does not define one universal risk standard, threat library, sector regime, control catalog, evidence retention period, or recovery target; these remain scope-specific gaps.

190

SECTION 190 - APPLICATION SECURITY

CODEX/03_SECTIONS/190_APPLICATION_SECURITY.txt

SHA-256 ef596a3add240475be73090055313c446490059cc0cdc9d6e5e241fd4d22f00a

6,491 BYTES / PRESERVED SOURCE IDENTITY

SECTION 190 — Application Security

STATUS: CONTENT-COMPLETE

PURPOSE

Engineer security into application behavior, code, dependencies, interfaces, configuration, data handling, identity paths, and lifecycle workflows so applications resist misuse and fail safely.

REQUIRED OUTCOME

- Application threat model, security requirements, secure design patterns, ownership, and trust boundaries.
- Verified protections for input, output, identity, authorization, secrets, dependencies, data, sessions, errors, logging, and recovery.
- Security evidence and remediation decisions linked to exact artifacts and runtime environments.

WHY THIS MATTERS

Application defects are often reachable through ordinary user and integration paths. A build can succeed while injection, privilege escalation, data leakage, insecure defaults, or unsafe recovery remains exploitable.

APPLICABILITY

Applies to web, mobile, desktop, service, API, batch, event, agent, plugin, and administrative applications, including code, configuration, libraries, pipelines, and runtime interfaces.

NON-APPLICABILITY CONDITIONS

Only where an approved application security baseline covers exact artifact, version, configuration, environment, data, interface, and change with no material effect. Prototypes remain proposed and cannot claim secure implementation.

PREREQUISITES AND DEPENDENCIES

Sections 019, 030-032, 045-048, 107-129, 246, 260, 270, and 301-309 provide requirements, information, application, identity, security, engineering, testing, dependency, delivery, and operations context.

REQUIRED INPUTS

Source and build artifacts, dependency inventory, data flows, identities, roles, endpoints, threat model, coding standards, security requirements, configurations, test results, vulnerabilities, incidents, and release boundaries.

HUMAN RESPONSIBILITIES AND AUTHORITY

Humans approve security requirements, risk, release, exceptions, disclosure, remediation deadlines, and acceptance. Owners must provide qualified review and retain authority to stop, isolate, roll back, or retire the application.

AI RESPONSIBILITIES AND BOUNDARIES

AI may review authorized code and artifacts, identify patterns, draft tests, and suggest remediation. It must not invent execution evidence, expose secrets, modify production, waive findings, or declare security from static analysis or generated code.

APPLICABLE EXISTING AGENT ROLES

Architect, Implementer, Refactorer, Security Auditor, Tester, Verifier, Red Team, Analyst, Critic, Governance Reviewer, Observer, Documentation Writer, Memory Curator, and Planner.

REQUIRED ACTIVITIES

1. Map application assets, actors, data flows, privileges, entry points, dependencies, and trust boundaries.
2. Model abuse cases and derive secure requirements.
3. Apply secure design, coding, dependency, configuration, secret, and error-handling controls.
4. Test authentication, authorization, validation, injection, session, upload, logging, privacy, resilience, and recovery paths.
5. Triage findings by exploitability and impact, assign owners, and verify remediation.
6. Baseline release evidence and hand off unresolved risk.

HUMAN-AI INTERACTION REQUIREMENTS

Show code or runtime evidence separately from AI suggestions. Human review is required for privilege, data disclosure, release, exception, and destructive remediation. Preserve manual status, evidence, correction, and rollback paths; do not let chat bypass application controls.

ARCHITECTURE AND SYSTEM IMPLICATIONS

Use secure-by-default boundaries, least privilege, typed and validated interfaces, safe error handling, dependency pinning, secret isolation, tamper-evident logs, rate limits, abuse detection, and independent recovery. Keep source, build, deploy, and runtime identities distinct.

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show artifact, version, environment, findings, exploitability, evidence freshness, remediation, approvals, and residual risk. Authorized controls include quarantine, revoke, block release, roll back, rotate, restore, accept, and reopen.

REQUIRED OUTPUTS AND ARTIFACTS

Threat model, secure design review, security requirements, dependency and secret inventory, code review, test results, findings, remediation records, release gate, exception, incident, and handoff package.

EVIDENCE REQUIREMENTS

Identify artifact, commit, build, environment, tool, rules, coverage, method, result, reviewer, date, and limits. A clean scan or passing test is not proof of absence of vulnerabilities.

VERIFICATION AND ACCEPTANCE TESTS

Test malicious input, authorization boundaries, session expiry, concurrency, error paths, dependency compromise, secret exposure, logging, rate limits, data minimization, rollback, and recovery. Reproduce material findings independently.

FAILURE STATES AND ANTI-PATTERNS

Relying on scanners alone; unvalidated input; client-only authorization; secrets in code or logs; unbounded uploads; verbose errors; ignored dependencies; shared admin paths; silent findings suppression; and release approval based on green CI alone.

RECOVERY AND RECONSIDERATION

Contain vulnerable behavior, preserve artifacts and logs, revoke or rotate affected credentials, patch or compensate through approved change, retest, reassess exposed data and downstream decisions, and reopen when code, dependency, interface, threat, or environment changes.

COMPLETION CRITERIA

Every material application path has owners, threats, requirements, controls, tests, evidence, remediation, recovery, and acceptance status. Gaps and expiry are visible; section remains CONTENT-COMPLETE until qualified review and owner acceptance.

HANDOFF AND CONTINUITY REQUIREMENTS

Preserve commit, build, dependency, configuration, findings, decisions, evidence, exceptions, incidents, and next action. Hand off to Product, Software, Platform, Identity, Privacy, Testing, DevSecOps, Operations, Incident Response, and Retirement sections.

RELATED CODEX SECTIONS

019 Requirements Engineering; 032 Application Architecture; 045 Security Architecture; 046 Identity; 047 Privacy; 107-129 software and application engineering; 246, 255, 260, 270, 301-309, 380-381, 405-406.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

Uses the Canonical Section Contract and neighboring architecture, engineering, testing, and governance sections. Universal secure coding rules, supported stacks, threat coverage, vulnerability severity, and disclosure obligations remain unresolved until scope is supplied.

191

SECTION 191 - PRODUCT SECURITY

CODEX/03_SECTIONS/191_PRODUCT_SECURITY.txt

SHA-256 11a8318c1c7e63b0c2a23b37ed134ccd8578639fbede9991961a8c4028690015

6,967 BYTES / PRESERVED SOURCE IDENTITY

SECTION 191 — Product Security

STATUS: CONTENT-COMPLETE

PURPOSE

Govern the security of a product from concept through design, development, release, use, support, update, and retirement, including customer-facing behavior, supply chain, commitments, and abuse resistance.

REQUIRED OUTCOME

- Product security objectives, threat model, security requirements, accountable owners, release gates, support commitments, and retirement conditions.
- Security controls and evidence spanning design, build, delivery, deployment, use, update, incident, and customer communication.
- A risk and vulnerability process that protects users without concealing limitations or shifting unbounded burden to customers.

WHY THIS MATTERS

Customers experience the security of the whole product, including defaults, integrations, documentation, update paths, support, and supplier behavior. A secure component can still create an unsafe product promise or operational dependency.

APPLICABILITY

Applies to products, services, devices, platforms sold or provided to users, internal products with material users, managed offerings, SDKs, APIs, models, and productized AI capabilities.

NON-APPLICABILITY CONDITIONS

Only when an approved product-security baseline covers exact product, release, users, threat environment, dependencies, and lifecycle change. Research prototypes may be scoped as proposed and must not imply customer readiness.

PREREQUISITES AND DEPENDENCIES

Sections 005-010, 018-020, 032, 045-050, 107-150, 179-188, 246, 260, 270, 287-297, and 301-406 provide product, risk, system, application, security, engineering, AI, testing, delivery, operations, and lifecycle context.

REQUIRED INPUTS

Product goals, users, abuse cases, customer promises, data and identity flows, threat model, architecture, dependencies, suppliers, release plan, support model, vulnerability history, update capability, and retirement obligations.

HUMAN RESPONSIBILITIES AND AUTHORITY

Product and security owners decide acceptable risk, customer commitments, release, disclosure, exceptions, support, and retirement. They must ensure affected users and qualified security, privacy, safety, accessibility, legal, and operations authorities participate.

AI RESPONSIBILITIES AND BOUNDARIES

AI may compare product requirements, identify abuse cases, analyze vulnerabilities, draft controls and communications, and propose tests. It cannot promise security, suppress findings, invent customer impact, approve release, or disclose incidents without human authority.

APPLICABLE EXISTING AGENT ROLES

Architect, Product Manager, Analyst, Researcher, Security Auditor, Governance Reviewer, Implementer, Tester, Verifier, Observer, Critic, Red Team, Documentation Writer, Memory Curator, Coordinator, and Planner.

REQUIRED ACTIVITIES

1. Define product scope, users, protected outcomes, promises, lifecycle, and accountability.
2. Model product attack surface, abuse, dependencies, supply chain, update, support, and customer responsibility boundaries.
3. Derive security requirements and release, disclosure, support, and retirement gates.
4. Validate defaults, documentation, controls, update paths, integrations, accessibility, privacy, and failure behavior.
5. Exercise hostile use, dependency compromise, account loss, update failure, incident communication, and recovery.
6. Baseline residual risk and hand off support, operations, vulnerability, and retirement obligations.

HUMAN-AI INTERACTION REQUIREMENTS

Show product claims separately from verified evidence, customer configuration, and AI recommendations. Human approval is required for commitments, release, exceptions, disclosure, and changes affecting user rights or safety. Preserve accessible reporting, status, correction, and recovery paths.

ARCHITECTURE AND SYSTEM IMPLICATIONS

Connect product requirements to architecture, code, dependencies, configuration, documentation, telemetry, support, update, and retirement records. Design secure defaults, tenant isolation, update integrity, backward compatibility, abuse controls, and customer-visible limitations.

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show product release, version, threat exposure, findings, support status, update state, customer impact, evidence freshness, exceptions, and available containment or retirement actions with authority.

REQUIRED OUTPUTS AND ARTIFACTS

Product security charter, threat and abuse model, security requirements, customer responsibility matrix, supply-chain inventory, release gate, test evidence, vulnerability and disclosure process, support runbook, incident communications, and retirement record.

EVIDENCE REQUIREMENTS

Identify product version, configuration, population, environment, method, coverage, result, owner, date, and limitations. Marketing, certification, benchmark, scan, or pilot evidence proves only its stated scope and period.

VERIFICATION AND ACCEPTANCE TESTS

Verify secure defaults, tenant separation, update authenticity, rollback, integrations, privacy, accessibility, abuse reporting, rate limits, failure, support, disclosure, and customer recovery. Independently reproduce material claims.

FAILURE STATES AND ANTI-PATTERNS

Security theater through badges or marketing; insecure defaults; unclear customer responsibility; unpatchable deployments; unsupported versions; hidden telemetry; silent supplier risk; hostile user assumptions; and minimizing incident impact to protect reputation.

RECOVERY AND RECONSIDERATION

Contain affected product behavior, preserve evidence, notify authorized parties, provide mitigations or safe degradation, patch or compensate, verify customer impact, and reopen commitments when threat, dependency, population, release, or evidence changes.

COMPLETION CRITERIA

Product scope, owners, users, threats, requirements, controls, lifecycle, support, update, evidence, tests, recovery, disclosure, residual risk, and acceptance are explicit. Status remains CONTENT-COMPLETE pending qualified review and owner acceptance.

HANDOFF AND CONTINUITY REQUIREMENTS

Preserve product identity, release, dependencies, customer obligations, decisions, evidence, findings, communications, dissent, and next action. Hand off to Application, Platform, Cloud, Infrastructure, Privacy, Trust and Safety, Vulnerability, Incident, Support, and Retirement sections.

RELATED CODEX SECTIONS

005-010 Strategy and Management; 018-020 Risk through Systems Engineering; 032-060 architecture; 190 Application Security; 209-218 vulnerability, testing, incident, fraud, abuse, trust, and privacy; 287-297 release and change; 301-406 operations and retirement.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

Based on the Canonical Section Contract and supplied neighboring sections. No universal product-security standard, customer contract, disclosure timeline, support duration, certification, threat population, or update guarantee is supplied; these remain scope-specific gaps.

192

SECTION 192 - PLATFORM SECURITY

CODEX/03_SECTIONS/192_PLATFORM_SECURITY.txt

SHA-256 7415ecc052956c47e05f8e35a8083f1268696ca8f71fd0fde925ffe8d11e175e

6,982 BYTES / PRESERVED SOURCE IDENTITY

SECTION 192 — Platform Security

STATUS: CONTENT-COMPLETE

PURPOSE

Define and engineer security for shared platforms that host, connect, build, deploy, observe, or govern workloads, preserving tenant isolation, administrative control, availability, integrity, and evidence.

REQUIRED OUTCOME

- Platform assets, tenants, trust zones, administrative roles, control objectives, dependencies, and operating modes.
- Enforced isolation, identity, authorization, configuration, patching, secrets, monitoring, recovery, and supply-chain controls.
- Evidence linking platform state to workload impact, exceptions, incident response, and safe change.

WHY THIS MATTERS

A platform failure or privileged compromise can multiply across workloads. Shared services create concentration risk, hidden authority, cross-tenant leakage, and recovery dependencies that local application controls cannot fully address.

APPLICABILITY

Applies to runtime, container, orchestration, developer, CI/CD, data, identity, observability, integration, edge, hosting, and shared service platforms, including managed providers and control planes.

NON-APPLICABILITY CONDITIONS

Only when an approved platform-security baseline covers the exact platform, version, tenants, control plane, region, configuration, and change. A disposable isolated lab may record justified limited scope but not production security.

PREREQUISITES AND DEPENDENCIES

Sections 032-044, 045-052, 107-150, 258-281, 301-318, and 326-330 provide application, platform, infrastructure, security, reliability, engineering, delivery, operations, observability, continuity, and recovery context.

REQUIRED INPUTS

Platform inventory, tenancy, trust zones, identities, roles, workloads, data, network paths, control-plane APIs, configurations, providers, images, dependencies, vulnerabilities, telemetry, recovery targets, and change history.

HUMAN RESPONSIBILITIES AND AUTHORITY

Platform owners approve isolation, privileged access, risk, changes, exceptions, availability tradeoffs, incident severity, recovery, and retirement. They must coordinate workload owners and independent security, privacy, resilience, and operations authorities.

AI RESPONSIBILITIES AND BOUNDARIES

AI may analyze authorized configuration, inventory, telemetry, drift, dependencies, and attack paths. It cannot alter shared state, grant access, suppress alerts, accept tenant risk, or claim isolation from configuration similarity or a successful deployment.

APPLICABLE EXISTING AGENT ROLES

Architect, Platform Engineer, Infrastructure Engineer, Security Auditor, Identity Engineer, Network Engineer, Analyst, Observer, Implementer, Tester, Verifier, Red Team, Governance Reviewer, Operations Engineer, Documentation Writer, and Memory Curator.

REQUIRED ACTIVITIES

1. Inventory platform assets, tenants, control planes, trust boundaries, privileged paths, and shared dependencies.
2. Model threats including escape, cross-tenant access, supply-chain compromise, denial, misconfiguration, and operator error.
3. Define isolation, identity, authorization, hardening, patch, configuration, secret, logging, detection, and recovery controls.
4. Test tenant separation, privilege boundaries, image and package provenance, change, failure, restore, and evidence paths.
5. Monitor drift, capacity, dependency exposure, and control effectiveness; remediate or contain by authority.
6. Baseline platform state and hand off workload impact and open risk.

HUMAN-AI INTERACTION REQUIREMENTS

Expose platform versus workload evidence, shared blast radius, acting identity, scope, authority, and consequence. Human review is required for privilege, isolation, failover, broad changes, and exceptions. Preserve workload-level fallback and owner control during platform or AI failure.

ARCHITECTURE AND SYSTEM IMPLICATIONS

Use explicit tenant and trust boundaries, least privilege, immutable or attestable artifacts, policy-enforced configuration, separate control and data planes, blast-radius limits, secure defaults, independent monitoring, and recovery paths that do not depend solely on the failed control plane.

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show platform version, regions, tenants, control state, privileged sessions, drift, dependencies, incidents, evidence freshness, exceptions, and available isolate, revoke, failover, restore, or retire actions.

REQUIRED OUTPUTS AND ARTIFACTS

Platform asset and tenancy catalog, trust-boundary model, threat model, control matrix, privileged-access design, configuration baseline, supply-chain evidence, drift findings, test and recovery results, exception register, and continuity handoff.

EVIDENCE REQUIREMENTS

Identify platform, version, region, tenant population, configuration, method, tool, time, result, owner, coverage, and limitation. Compliance reports, templates, uptime, and deployment success prove only bounded conditions.

VERIFICATION AND ACCEPTANCE TESTS

Exercise escape and cross-tenant attempts, privilege changes, stale credentials, malicious artifacts, control-plane loss, network partition, capacity exhaustion, drift, failover, restore, and evidence replay. Reproduce critical results independently.

FAILURE STATES AND ANTI-PATTERNS

Shared admin credentials; tenant isolation by convention; mutable base images; unreviewed provider access; control-plane single point of recovery; hiding blast radius; ignoring region or supplier dependencies; and treating configuration conformance as runtime security.

RECOVERY AND RECONSIDERATION

Freeze or isolate affected zones, revoke credentials, preserve platform and workload evidence, communicate impact, restore from approved known-good state, validate tenant and data boundaries, and reopen when topology, provider, version, threat, or recovery assumptions change.

COMPLETION CRITERIA

Assets, tenants, boundaries, owners, controls, evidence, tests, recovery, residual risk, exceptions, and workload handoff are explicit. Section remains CONTENT-COMPLETE until qualified review and owner acceptance.

HANDOFF AND CONTINUITY REQUIREMENTS

Preserve platform identity, configuration, versions, tenants, dependencies, privileged decisions, evidence, incidents, dissent, and next action. Hand off to Infrastructure, Cloud, Network, Identity, Application, Data, Security Operations, Incident Response, Reliability, Testing, and Retirement.

RELATED CODEX SECTIONS

032-044 Application through Runtime Architecture; 045-052 Security through Resilience Architecture; 190, 193-206 security engineering; 258-281 configuration, delivery, platform, infrastructure, and container sections; 301-330 operations and recovery.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

Uses the Canonical Section Contract and neighboring architecture, engineering, operations, and governance sections. Platform type, tenancy model, provider, regulatory regime, isolation evidence, recovery target, and control catalog remain unresolved until scope is supplied.

193

SECTION 193 - INFRASTRUCTURE SECURITY

CODEX/03_SECTIONS/193_INFRASTRUCTURE_SECURITY.txt

SHA-256 5923085ce9d08ee83b8e0eaeeed49f4b8b4c9064087bb19b833a3c0d568a9167

5,437 BYTES / PRESERVED SOURCE IDENTITY

SECTION 193 — Infrastructure Security

STATUS: CONTENT-COMPLETE

PURPOSE

Protect physical and virtual infrastructure, hosts, storage, operating environments, provisioning paths, administrative planes, and supporting facilities throughout their lifecycle.

REQUIRED OUTCOME

Infrastructure assets, trust zones, owners, hardening baselines, privileged paths, patching, monitoring, isolation, backup, recovery, and evidence are explicit and tested.

WHY THIS MATTERS

Infrastructure is a common blast-radius boundary. Weak host, image, storage, firmware, or provisioning controls can defeat application security and erase recovery evidence.

APPLICABILITY

Applies to servers, hosts, hypervisors, storage, images, operating systems, facilities, provisioning, administrative tooling, and physical or virtual infrastructure.

NON-APPLICABILITY CONDITIONS

Only an approved baseline covering exact assets, versions, configurations, locations, privileges, and changes may justify non-applicability; labs remain limited-scope evidence.

PREREQUISITES AND DEPENDENCIES

Sections 020, 032-040, 045, 051-052, 258-286, 301-330, and 398-400 provide system, platform, network, security, resilience, infrastructure, operations, and disposal context.

REQUIRED INPUTS

Asset inventory, ownership, topology, images, firmware, configurations, identities, access, data, dependencies, patch history, vulnerabilities, telemetry, backup, restore, and facility constraints.

HUMAN RESPONSIBILITIES AND AUTHORITY

Infrastructure owners approve hardening, privileged access, maintenance, exceptions, outage risk, recovery, and retirement; qualified security and operations authorities must review material changes.

AI RESPONSIBILITIES AND BOUNDARIES

AI may inventory, compare configurations, detect drift, and propose tests. It cannot grant access, change hosts, suppress evidence, or claim security from configuration similarity or successful provisioning.

APPLICABLE EXISTING AGENT ROLES

Architect, Infrastructure Engineer, Systems Administrator, Security Auditor, Network Engineer, Implementer, Tester, Verifier, Observer, Red Team, Governance Reviewer, Operations Engineer, and Documentation Writer.

REQUIRED ACTIVITIES

1. Inventory hosts, storage, images, firmware, control planes, facilities, and trust boundaries.

2. Define secure baselines, least privilege, segmentation, patching, provenance, monitoring, and recovery controls.
3. Review configuration and supply-chain drift; test isolation, tampering, denial, restore, and evidence capture.
4. Record residual risk, exceptions, remediation, and lifecycle handoff.

HUMAN-AI INTERACTION REQUIREMENTS

Separate observed state from AI analysis. Human approval is required for privileged changes, isolation, outage, recovery, and exceptions; manual status and recovery remain available when automation fails.

ARCHITECTURE AND SYSTEM IMPLICATIONS

Use immutable or attestable images, controlled provisioning, segmented management planes, secure boot where applicable, least privilege, encrypted storage, tamper-evident logs, independent backups, and recovery not dependent on the failed host.

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show asset, version, location, owner, hardening, privileged sessions, drift, findings, evidence freshness, outage impact, and authorized isolate, patch, restore, or retire actions.

REQUIRED OUTPUTS AND ARTIFACTS

Infrastructure inventory, threat model, hardening baseline, access matrix, patch and image records, configuration evidence, vulnerability findings, recovery tests, exceptions, and handoff package.

EVIDENCE REQUIREMENTS

Identify asset, version, configuration, environment, method, coverage, date, result, owner, and limits. A template, scan, or uptime signal proves only its bounded condition.

VERIFICATION AND ACCEPTANCE TESTS

Exercise unauthorized administration, image tampering, storage disclosure, host compromise, patch failure, management-plane loss, capacity exhaustion, restore, and evidence replay.

FAILURE STATES AND ANTI-PATTERNS

Shared administrators, unmanaged images, unpatched hosts, public management ports, unencrypted backups, single recovery paths, ignored physical access, and treating provisioning success as security.

RECOVERY AND RECONSIDERATION

Isolate affected assets, revoke credentials, preserve evidence, restore known-good infrastructure, validate dependent workloads and data, and reopen when topology, firmware, provider, or threat assumptions change.

COMPLETION CRITERIA

Assets, boundaries, owners, controls, evidence, tests, recovery, exceptions, residual risk, and retirement are explicit; status remains CONTENT-COMPLETE pending qualified review and acceptance.

HANDOFF AND CONTINUITY REQUIREMENTS

Preserve asset identity, configuration, versions, incidents, decisions, evidence, dissent, and next action. Hand off to Platform, Cloud, Network, Security Operations, Incident Response, Reliability, Backup, Testing, and Disposal.

RELATED CODEX SECTIONS

035 Infrastructure Architecture; 045 Security Architecture; 051-052 Reliability and Resilience; 193-206 security sections; 258-286 environment and infrastructure operations; 328-330 recovery; 398-400 disposal.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

The contract and neighboring architecture sections govern this draft. Hardware, operating system, facility, provider, regulatory, hardening, and recovery standards remain scope-specific gaps.

194

SECTION 194 - CLOUD SECURITY

CODEX/03_SECTIONS/194_CLOUD_SECURITY.txt

SHA-256 c98fc259ded42060203dd8a19bbb659fd1e2a8bb87363081bda500ec47a1eb24

5,430 BYTES / PRESERVED SOURCE IDENTITY

SECTION 194 — Cloud Security

STATUS: CONTENT-COMPLETE

PURPOSE

Engineer security for cloud accounts, subscriptions, tenants, regions, services, control planes, workload identities, data, and provider relationships.

REQUIRED OUTCOME

Cloud scope, account ownership, tenancy, identity, policy, network, data, logging, provider responsibility, resilience, recovery, and evidence are explicit.

WHY THIS MATTERS

Cloud centralizes powerful control and creates opaque provider dependencies. Mis-scoped identity or policy can expose many workloads at once and complicate evidence and recovery.

APPLICABILITY

Applies to public, private, hybrid, multi-cloud, managed services, cloud-native applications, accounts, subscriptions, regions, and provider control planes.

NON-APPLICABILITY CONDITIONS

Non-applicability requires an approved exact cloud baseline with no material account, tenancy, provider, data, identity, region, or configuration change.

PREREQUISITES AND DEPENDENCIES

Sections 032-046, 048-052, 258-281, 301-330, and 348-350 provide application, platform, identity, governance, resilience, delivery, cloud, operations, recovery, and supplier context.

REQUIRED INPUTS

Accounts, tenants, regions, services, provider contracts, shared responsibility, identities, policies, networks, data, keys, logs, workloads, dependencies, incidents, and recovery objectives.

HUMAN RESPONSIBILITIES AND AUTHORITY

Cloud and workload owners approve account structure, provider access, policy, region, data, exceptions, recovery, and risk. Humans retain authority over provider commitments and disclosure.

AI RESPONSIBILITIES AND BOUNDARIES

AI may analyze authorized cloud state, policy drift, cost-security tradeoffs, and telemetry. It cannot change cloud resources, grant roles, accept provider risk, or infer tenant isolation.

APPLICABLE EXISTING AGENT ROLES

Cloud Architect, Platform Engineer, Security Auditor, Identity Engineer, Network Engineer, Analyst, Implementer, Tester, Verifier, Red Team, Governance Reviewer, Observer, and Operations Engineer.

REQUIRED ACTIVITIES

1. Map accounts, tenants, regions, control planes, provider responsibilities, and trust boundaries.

2. Define identity, policy, network, data, logging, configuration, workload, and recovery controls.
3. Assess provider, region, service, supply-chain, and shared-responsibility risk.
4. Test isolation, policy enforcement, key loss, region loss, provider outage, restore, and evidence access.
5. Baseline exceptions and hand off operational controls.

HUMAN-AI INTERACTION REQUIREMENTS

Expose provider evidence versus local verification, acting identity, scope, authority, and blast radius. Human approval is required for broad policy, privileged roles, region changes, incident disclosure, and recovery.

ARCHITECTURE AND SYSTEM IMPLICATIONS

Use landing-zone boundaries, deny-by-default policy, short-lived workload identity, segmented networks, centralized logs, immutable evidence, encryption, service quotas, provider substitution, and tested multi-zone or multi-region recovery.

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show account, tenant, region, service, policy, identity, findings, provider status, evidence freshness, data location, and authorized restrict, revoke, isolate, failover, restore, or retire actions.

REQUIRED OUTPUTS AND ARTIFACTS

Cloud asset map, shared-responsibility matrix, threat model, policy baseline, identity and network design, provider evidence, drift findings, recovery tests, exceptions, and continuity handoff.

EVIDENCE REQUIREMENTS

Identify provider, account, region, service, configuration, population, method, time, result, owner, and limit. Provider attestations and dashboards prove only their stated scope.

VERIFICATION AND ACCEPTANCE TESTS

Exercise cross-tenant access, policy bypass, credential compromise, public exposure, region loss, provider outage, quota exhaustion, logging loss, restore, and evidence replay.

FAILURE STATES AND ANTI-PATTERNS

Trusting provider defaults, confusing compliance with security, broad permanent roles, unlogged control-plane actions, single-region recovery, hidden data residency, and cloud automation without approval.

RECOVERY AND RECONSIDERATION

Restrict or isolate affected accounts and services, revoke roles, preserve local and provider evidence, invoke approved substitution or restore, validate data and identity impact, and reopen on provider, region, policy, or threat change.

COMPLETION CRITERIA

Cloud scope, ownership, responsibility, controls, evidence, recovery, provider limits, exceptions, and acceptance are explicit; status remains CONTENT-COMPLETE pending qualified review.

HANDOFF AND CONTINUITY REQUIREMENTS

Preserve account, tenant, region, service, provider, policy, identity, decision, evidence, incident, dissent, and next action. Hand off to Platform, Infrastructure, Network, Identity, Data, Operations, Reliability, Incident, and Retirement.

RELATED CODEX SECTIONS

036 Cloud Architecture; 045-052 security and resilience architecture; 193, 195-206 security sections; 276-281 infrastructure and container engineering; 304, 310, 327-330 cloud operations and recovery.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

No universal provider, tenancy, region, responsibility, regulatory, evidence, or recovery standard is supplied. Actual contracts, account structures, data residency, and provider controls remain unresolved.

195

SECTION 195 - NETWORK SECURITY

CODEX/03_SECTIONS/195_NETWORK_SECURITY.txt

SHA-256 4d0a6c5cf078dffe0df9f312d20dfc6515ab9c628e9c5e1a61312690abe11438

5,154 BYTES / PRESERVED SOURCE IDENTITY

SECTION 195 — Network Security

STATUS: CONTENT-COMPLETE

PURPOSE

Protect network paths, boundaries, protocols, names, routing, wireless, remote access, and communications against unauthorized use, disclosure, disruption, and manipulation.

REQUIRED OUTCOME

Network assets, zones, flows, owners, identities, policy, encryption, monitoring, availability, segmentation, incident, recovery, and evidence are explicit.

WHY THIS MATTERS

Networks carry trust and control between otherwise protected components. A route, name, certificate, or management path can bypass local controls or make recovery impossible.

APPLICABILITY

Applies to enterprise, cloud, data center, wireless, edge, internet, operational, partner, service-mesh, and management networks and their protocols and providers.

NON-APPLICABILITY CONDITIONS

Only an approved exact topology, flow, protocol, identity, policy, environment, and change baseline can justify non-applicability.

PREREQUISITES AND DEPENDENCIES

Sections 039-040, 045-046, 051-052, 193-206, 284, 301, 305, 313-318, and 326-330 provide network, security, identity, resilience, operations, observability, and recovery context.

REQUIRED INPUTS

Topology, zones, flows, protocols, addresses, names, devices, identities, keys, firewall policy, dependencies, traffic baselines, providers, threats, telemetry, and recovery paths.

HUMAN RESPONSIBILITIES AND AUTHORITY

Network owners approve topology, policy, privileged access, monitoring, exceptions, outage, segmentation, and recovery with security, privacy, safety, and operations review.

AI RESPONSIBILITIES AND BOUNDARIES

AI may map authorized flows, detect anomalies, and propose policy or tests. It cannot alter routes or rules, infer safe traffic, suppress alerts, or declare segmentation effective without evidence.

APPLICABLE EXISTING AGENT ROLES

Network Architect, Network Engineer, Security Auditor, Identity Engineer, Analyst, Observer, Implementer, Tester, Verifier, Red Team, Governance Reviewer, and Operations Engineer.

REQUIRED ACTIVITIES

1. Inventory zones, flows, protocols, names, devices, identities, and trust boundaries.

2. Define least-access policy, segmentation, encrypted transport, management isolation, logging, detection, and recovery.
3. Review changes and providers; test unauthorized paths, spoofing, denial, partition, failover, and restore.
4. Baseline evidence, exceptions, and downstream owner impact.

HUMAN-AI INTERACTION REQUIREMENTS

Show observed traffic, inferred behavior, proposed policy, and enforced state separately. Human approval is required for broad rules, isolation, emergency access, and outage-risk changes.

ARCHITECTURE AND SYSTEM IMPLICATIONS

Use deny-by-default boundaries, authenticated protocols, segmentation, egress control, secure naming, independent management, resilient routing, time-bounded exceptions, and telemetry protected from tampering.

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show topology, zones, flows, rules, identities, anomalies, dependencies, evidence freshness, blast radius, and authorized block, isolate, reroute, restore, or retire controls.

REQUIRED OUTPUTS AND ARTIFACTS

Network map, flow inventory, threat model, rule and identity matrix, protocol standards, monitoring design, change records, tests, incident and recovery evidence, exceptions, and handoff.

EVIDENCE REQUIREMENTS

Identify topology, rule version, capture period, population, method, tool, result, owner, and limits. A diagram, scan, or flow sample proves only its bounded view.

VERIFICATION AND ACCEPTANCE TESTS

Exercise spoofing, unauthorized routes, lateral movement, DNS failure, certificate expiry, wireless compromise, partition, congestion, provider loss, failover, and evidence replay.

FAILURE STATES AND ANTI-PATTERNS

Flat networks, broad firewall rules, shared admin access, unmanaged wireless, unauthenticated protocols, hidden tunnels, no egress control, alert suppression, and recovery dependent on the failed network.

RECOVERY AND RECONSIDERATION

Contain or isolate paths, preserve captures and configuration, revoke credentials, invoke approved alternate communications, restore known-good policy, validate workloads, and reopen after topology or threat change.

COMPLETION CRITERIA

Flows, owners, policies, evidence, tests, recovery, exceptions, and acceptance are explicit; status remains CONTENT-COMPLETE pending independent review and owner acceptance.

HANDOFF AND CONTINUITY REQUIREMENTS

Preserve topology, rules, identities, providers, incidents, decisions, evidence, dissent, and next action. Hand off to Cloud, Platform, Infrastructure, Identity, Communications, Security Operations, Incident, Testing, and Recovery.

RELATED CODEX SECTIONS

039 Network Architecture; 040 Communications Architecture; 045-046 Security and Identity; 194 Cloud; 195-206 security; 284 Network Engineering; 305 Network Operations; 313-318 observability; 327-330 recovery.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

Protocol, provider, topology, jurisdiction, retention, traffic, monitoring, and recovery standards are not universal in the supplied Codex and remain scope-specific gaps.

196

SECTION 196 - ENDPOINT SECURITY

CODEX/03_SECTIONS/196_ENDPOINT_SECURITY.txt

SHA-256 25a72814a436f8025c80d1dab187e9608bc914245ff986dc271b0639058a3e19

5,294 BYTES / PRESERVED SOURCE IDENTITY

SECTION 196 — Endpoint Security

STATUS: CONTENT-COMPLETE

PURPOSE

Protect user, operator, server, mobile, virtual, and specialized endpoints through identity, configuration, software, data, telemetry, response, and lifecycle controls.

REQUIRED OUTCOME

Endpoint inventory, ownership, posture, access, software, patching, encryption, isolation, monitoring, response, recovery, and disposal are explicit and verifiable.

WHY THIS MATTERS

Endpoints are where people and physical systems meet untrusted content and credentials. Lost, compromised, unmanaged, or shared devices can bypass architecture and expose sensitive work.

APPLICABILITY

Applies to workstations, servers, mobile devices, virtual desktops, kiosks, field devices, privileged consoles, and endpoint management systems.

NON-APPLICABILITY CONDITIONS

Only an approved exact endpoint population, operating system, management boundary, configuration, user group, and lifecycle change can justify non-applicability.

PREREQUISITES AND DEPENDENCIES

Sections 032-040, 045-046, 193-195, 197-206, 258-286, 301-318, and 398-400 provide application, architecture, security, network, endpoint, identity, engineering, operations, and disposal context.

REQUIRED INPUTS

Endpoint inventory, owner, user, location, operating system, software, configuration, identity, data, management, patch, vulnerability, telemetry, incident, backup, and disposal records.

HUMAN RESPONSIBILITIES AND AUTHORITY

Endpoint owners authorize enrollment, access, monitoring, isolation, wipe, recovery, exceptions, and retirement while respecting privacy, labor, safety, and legal authority.

AI RESPONSIBILITIES AND BOUNDARIES

AI may assess posture and anomalies and propose containment. It cannot inspect beyond authorization, wipe or isolate without delegated authority, infer user intent, expose personal data, or close findings from a score.

APPLICABLE EXISTING AGENT ROLES

Endpoint Engineer, Security Auditor, Identity Engineer, Systems Administrator, Privacy Reviewer, Analyst, Observer, Implementer, Tester, Verifier, Red Team, Governance Reviewer, and Operations Engineer.

REQUIRED ACTIVITIES

1. Inventory and classify endpoints, users, data, management, and trust.

2. Define enrollment, hardening, patch, software, identity, encryption, isolation, monitoring, backup, and disposal controls.
3. Test lost device, malware, privilege, offline, stale policy, remote wipe, restore, and evidence paths.
4. Review posture, exceptions, user burden, and lifecycle evidence.

HUMAN-AI INTERACTION REQUIREMENTS

Show endpoint state, owner, user, posture, evidence freshness, privacy boundary, acting authority, and available quarantine, revoke, restore, or retire actions. Keep manual support and recovery available.

ARCHITECTURE AND SYSTEM IMPLICATIONS

Use managed enrollment, least privilege, secure boot where applicable, application control, encrypted storage, network segmentation, tamper-evident telemetry, offline limits, and independent recovery.

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show population, posture, software, patch, identity, anomalies, exposure, evidence, exceptions, and authorized isolate, wipe, restore, replace, or retire controls.

REQUIRED OUTPUTS AND ARTIFACTS

Endpoint catalog, baseline, management and identity matrix, software inventory, patch and vulnerability records, privacy assessment, tests, response and recovery runbooks, exceptions, and handoff.

EVIDENCE REQUIREMENTS

Identify endpoint population, version, user context, configuration, method, time, coverage, result, owner, and limitations. Enrollment or compliance status proves only the measured condition.

VERIFICATION AND ACCEPTANCE TESTS

Exercise malware, lost device, stale policy, local privilege, removable media, offline operation, management loss, remote action, restore, replacement, and evidence preservation.

FAILURE STATES AND ANTI-PATTERNS

Unmanaged devices, shared accounts, excessive monitoring, permanent admin, unpatched software, unenforced encryption, remote wipe without authority, and treating management enrollment as security.

RECOVERY AND RECONSIDERATION

Quarantine or revoke affected endpoints, preserve evidence, support affected users, restore or replace from approved state, validate data and identity impact, and reopen when population, platform, policy, or threat changes.

COMPLETION CRITERIA

Population, owners, controls, privacy, evidence, tests, recovery, exceptions, and disposal are explicit; status remains CONTENT-COMPLETE pending qualified review and acceptance.

HANDOFF AND CONTINUITY REQUIREMENTS

Preserve endpoint identity, user, posture, configuration, decisions, evidence, incidents, dissent, and next action. Hand off to Mobile, Embedded, Identity, Application, Network, Security Operations, Incident, Support, Recovery, and Disposal.

RELATED CODEX SECTIONS

CODEX/03_SECTIONS/196_ENDPOINT_SECURITY.txt

046 Identity Architecture; 193-195 and 197-206 security sections; 123 Mobile Engineering; 198 Embedded Security; 231-254 testing; 301-330 operations and recovery; 398-400 disposal.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

Endpoint types, monitoring authority, privacy boundaries, supported operating systems, patch windows, evidence retention, remote action rules, and disposal standards remain unresolved until scope is supplied.

197

SECTION 197 - MOBILE SECURITY

CODEX/03_SECTIONS/197_MOBILE_SECURITY.txt

SHA-256 e2765bfe8a7a5888e06f6122cce0e16f1f9bf9b928a573634e92697d85005ff3

12,760 BYTES / PRESERVED SOURCE IDENTITY

SECTION 197 — Mobile Security

STATUS: CONTENT-COMPLETE

PURPOSE

Define security for mobile applications, devices, identities, data, permissions, networks, distribution channels, and lifecycle controls across managed and unmanaged contexts.

REQUIRED OUTCOME

A mobile-security architecture and operating model that identifies assets, users, trust boundaries, threats, permissions, data handling, update paths, telemetry, response authority, recovery, and disposal for the exact platforms, versions, populations, and environments in scope.

WHY THIS MATTERS

Mobile systems combine personal devices, variable networks, local storage, app stores, sensors, identity providers, third-party SDKs, and physical loss. Enrollment, store approval, a clean scan, or a passing test is only bounded evidence and does not establish security for every device, user, version, or operating mode.

APPLICABILITY

Apply when a mobile application, mobile device, mobile identity, mobile endpoint, app store, mobile API, device-management service, sensor, local cache, or mobile support workflow can access information, perform actions, or affect a person, organization, or connected system.

NON-APPLICABILITY CONDITIONS

Mobile Security may be minimal when the artifact has no mobile software, device, identity, data, network, distribution, or operational effect and an approved analysis documents that conclusion. A web page viewed on a phone, a test-only emulator, or an unmanaged device does not automatically remove mobile obligations when data or authority crosses the boundary.

PREREQUISITES AND DEPENDENCIES

Use the applicable requirements, solution, application, identity, privacy, threat, data, network, platform, operations, incident, recovery, and disposal baselines. Identify supported platforms and versions, device ownership, management state, app distribution, backend services, SDKs, credentials, network paths, data stores, monitoring, support, and wipe or retirement authority.

REQUIRED INPUTS

- Mobile application and device inventory, versions, build provenance, signing identities, stores, SDKs, dependencies, and supported configurations.
- User, administrator, service, and device identity models, permissions, enrollment, authentication, authorization, session, and revocation rules.
- Data-flow, classification, local-storage, clipboard, backup, screenshot, notification, sensor, location, network, and synchronization behavior.
- Threats involving loss, theft, rooting, jailbreaking, malicious apps, overlays, phishing, reverse engineering, tampering, supply chain, offline use, and hostile networks.
- Mobile API contracts, telemetry, vulnerability results, update policy, support procedures, incident response, recovery, retention, and disposal obligations.

HUMAN RESPONSIBILITIES AND AUTHORITY

The accountable human owner approves supported platforms, acceptable risk, permissions, release, monitoring, data handling, device-management posture, exceptions, containment, wipe, user communication, and retirement. Security, privacy, legal, accessibility, platform, support, and operations owners must be assigned where their authority is affected. Humans decide whether a device or user may be blocked, whether data may be wiped, how appeals work, and when residual risk is accepted.

AI RESPONSIBILITIES AND BOUNDARIES

AI may inspect authorized mobile metadata, manifests, configurations, dependency records, threat models, telemetry, test results, and bounded logs; identify likely weaknesses; draft permission matrices, controls, tests, runbooks, and remediation options; and compare posture across declared versions.

AI must preserve device, app, platform, build, user, environment, source, time, and evidence boundaries. It must separate observed behavior from inferred threat, recommendation, executed action, and verified result, and must surface blind spots caused by unavailable devices, offline operation, missing telemetry, or private data.

AI must not infer permission from enrollment or device ownership, access or expose personal data, change production policy, release or withdraw an app, revoke a user, wipe a device, suppress an alert, or execute containment without explicit delegation, authorization, audit, and human control.

APPLICABLE EXISTING AGENT ROLES

Architect, Security Auditor, Researcher, Analyst, Observer, Implementer, Tester, Verifier, Governance Reviewer, Critic, Red Team, Documentation Writer, Memory Curator, Coordinator, and User Experience Reviewer. Select the smallest sufficient set and preserve the role contracts defined in Section 02.

REQUIRED ACTIVITIES

1. Establish supported platforms, versions, device ownership, management state, users, environments, data, actions, and lifecycle scope.
2. Inventory app binaries, signing, stores, SDKs, dependencies, APIs, permissions, identities, local stores, backups, and telemetry.
3. Map trust boundaries and threats for loss, theft, tampering, hostile networks, malicious apps, reverse engineering, phishing, supply chain, and offline use.
4. Define least-privilege permissions, authentication, authorization, session, key, secret, certificate, update, and revocation controls.
5. Specify protection for local and synchronized data, notifications, screenshots, clipboard, backups, logs, caches, sensors, and location.
6. Validate backend, mobile API, store, device-management, support, incident, recovery, and disposal dependencies.
7. Test release, update, rollback, offline, network change, rooted or jailbroken, lost-device, compromised-app, and account-recovery scenarios.
8. Record findings, evidence, exceptions, remediation, residual risk, owner decisions, user impact, and reopening conditions.

HUMAN-AI INTERACTION REQUIREMENTS

- Show the exact app, build, platform, device state, identity, data scope, authority, and time for each security conclusion.
- Require human review for permission changes, device blocking, wipe, release, exception, user notification, and any action affecting access or personal data.
- Keep manual support, accessible explanations, appeal, emergency contact, and recovery paths available when automated posture checks fail.
- Treat AI-generated threat hypotheses and remediation as proposals until independently verified against the actual mobile configuration and threat scope.
- Record prompts, tools, model or provider versions, retrieved evidence, human decisions, and executed actions for consequential assistance.

ARCHITECTURE AND SYSTEM IMPLICATIONS

- Separate app, device, user, service, store, management, API, network, data, and support trust boundaries.
- Bind permissions and policy to identity, app signature, version, device posture, purpose, and environment; do not use device enrollment as a substitute for authorization.
- Minimize local data and define encryption, key protection, cache, backup, clipboard, notification, screenshot, logging, and deletion behavior.
- Design for offline use, network transition, clock drift, provider failure, update interruption, revoked credentials, lost devices, and compromised clients.
- Make telemetry privacy-preserving, tamper-aware, attributable, time-bound, and useful for response without assuming full visibility.
- Treat third-party SDKs, stores, device-management services, mobile OS behavior, and backend APIs as versioned security dependencies.

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show app and device identity, build and platform, management state, owner, user impact, policy status, evidence freshness, open findings, permissions, data scope, and dependency health. Provide authorized controls to restrict access, revoke sessions, quarantine, notify, replace, restore, wipe, appeal, and retire. Explain why an action is proposed, what it affects, what evidence supports it, and what recovery remains. Do not expose private device content merely to make posture visible.

REQUIRED OUTPUTS AND ARTIFACTS

- Mobile asset, platform, build, identity, permission, data-flow, dependency, and trust-boundary inventories.
- Threat model, security requirements, control mapping, secure-storage and update design, and privacy impact record where applicable.
- Test plan and results for app, device, network, identity, offline, update, loss, compromise, recovery, and disposal scenarios.
- Vulnerability, remediation, exception, incident, communication, recovery, acceptance, decision, evidence, and continuity records.
- Owner cockpit definition, operational runbook, support and appeal procedures, and retirement or wipe plan.

EVIDENCE REQUIREMENTS

Every material claim identifies app and build, platform and version, device state, identity, environment, data scope, method, source, timestamp, result, limitation, and owner. Evidence may include reproducible tests, signed artifacts, configuration, dependency reports, telemetry, incident records, user reports, or controlled observations. Store approval, enrollment, a scan, or a single device test proves only its declared slice.

VERIFICATION AND ACCEPTANCE TESTS

- Verify least privilege, authentication, authorization, session expiry, revocation, signing, update, rollback, and dependency controls.
- Test local storage, keys, logs, backups, notifications, clipboard, screenshots, sensors, location, and deletion for each supported platform.
- Exercise offline use, hostile network, network change, clock change, rooted or jailbroken device, malicious app, overlay, reverse engineering, lost device, and account recovery.
- Verify backend APIs reject client-side bypass, stale sessions, unsupported versions, replay, tampering, and unauthorized data access.
- Reproduce findings and confirm evidence preservation, human authority, user notification, appeal, containment, restore, and wipe behavior.

FAILURE STATES AND ANTI-PATTERNS

- Treating device enrollment, store approval, certificate presence, or a clean scan as total security.
- Relying on client-side checks for authorization or storing secrets and sensitive data without a bounded reason.

- Ignoring unmanaged devices, offline operation, rooted devices, malicious apps, third-party SDKs, or platform drift.
- Wiping personal or organizational data without scope, authority, warning, recovery, and appeal controls.
- Collecting excessive location, sensor, telemetry, or device data and calling it security evidence without purpose or retention limits.
- Publishing a security conclusion from one build, device, platform, or happy-path test.

RECOVERY AND RECONSIDERATION

On suspected compromise, lost device, invalid evidence, unsafe permission, provider failure, or material platform drift, preserve evidence, narrow access, revoke affected sessions, and notify the accountable owner. Use approved containment, replacement, restore, re-enrollment, rollback, or selective wipe paths. Reassess personal impact, data loss, legal duties, user appeal, residual risk, and supported scope before restoring access. Reopen the section when the app, platform, identity, data, population, provider, policy, or threat changes.

COMPLETION CRITERIA

The exact mobile scope, assets, users, platforms, threats, permissions, data controls, dependencies, owners, evidence, tests, response, recovery, disposal, limitations, and reopening conditions are recorded. The owner has reviewed material risk and authority. Status remains CONTENT-COMPLETE until source reconciliation, independent verification, and owner acceptance are separately completed.

HANDOFF AND CONTINUITY REQUIREMENTS

Preserve inventory and baseline identity, supported versions, signing and release records, threat model, permissions, data flows, findings, exceptions, evidence, decisions, incident state, recovery steps, user communications, and open gaps. Hand off to Application, Identity, Privacy, Network, Platform, Security Operations, Incident Response, Testing, Support, Operations, and Disposal owners. State the next safe action and the exact condition that reopens this section.

RELATED CODEX SECTIONS

045-047 Security, Identity, and Privacy Architecture; 123 Mobile Engineering; 190 Application Security; 200-218 Identity, Security Operations, Threat, and Incident sections; 231-254 Testing; 301-330 Operations and Recovery; 398-400 Hardware Disposal and Secure Destruction.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

Based on the Canonical Section Contract, shared governance requirements, Sections 019-047, mobile engineering and application security context, and the section integration roadmap. Exact platforms, jurisdictions, device ownership, threat intelligence, provider contracts, privacy rules, telemetry limits, wipe authority, retention, accessibility, and owner acceptance evidence remain unresolved until supplied for the target system.

198

SECTION 198 - EMBEDDED SECURITY

CODEX/03_SECTIONS/198_EMBEDDED_SECURITY.txt

SHA-256 91a2d8c3b9849d895fbb28e9fa2295193bfb60bdb65c643cf13d76d92e42d232

10,792 BYTES / PRESERVED SOURCE IDENTITY

SECTION 198 — Embedded Security

STATUS: CONTENT-COMPLETE

PURPOSE

Secure embedded devices and software across hardware, firmware, interfaces, data, physical access, update, safety, operation, recovery, and disposal.

REQUIRED OUTCOME

A bounded security design for the exact device, firmware, hardware, interface, environment, threat scope, population, and lifecycle, including trust boundaries, keys, data, update paths, debug controls, safe states, telemetry, response authority, recovery, and evidence.

WHY THIS MATTERS

Embedded systems may control physical processes, operate offline, have limited observability, and remain deployed for years. A successful boot, bench test, certification, or clean scan proves only its declared slice and can miss tampering, unsafe updates, fault injection, debug abuse, power loss, supplier compromise, or recovery failure.

APPLICABILITY

Apply when software, firmware, electronics, sensors, actuators, controllers, appliances, vehicles, industrial equipment, medical devices, or other physical systems contain computation, connectivity, stored data, update capability, or security-relevant identity.

NON-APPLICABILITY CONDITIONS

The section may be minimal when no hardware, firmware, physical interface, embedded identity, stored data, safety effect, update path, or operational dependency is affected and an approved exact baseline records that conclusion. Simulation does not remove obligations when the simulated behavior stands in for a real device or control.

PREREQUISITES AND DEPENDENCIES

Use the applicable systems, hardware, firmware, safety, privacy, identity, cryptography, key, vulnerability, testing, operations, recovery, and disposal baselines. Identify device inventory, bill of materials, suppliers, build provenance, platform lifecycle, trust roots, interfaces, field conditions, maintenance authority, and safety constraints.

REQUIRED INPUTS

- Hardware and firmware inventory, versions, configurations, build and signing records, bill of materials, suppliers, and manufacturing or provisioning history.
- Data flows, local storage, sensors, actuators, interfaces, debug paths, network paths, credentials, certificates, keys, and update mechanisms.
- Threats involving physical access, tampering, cloning, extraction, fault injection, side channels, malicious peripherals, supply chain, and hostile environments.
- Safety requirements, safe-state behavior, maintenance procedures, telemetry, support, incident response, recovery, replacement, and disposal obligations.

HUMAN RESPONSIBILITIES AND AUTHORITY

The accountable owner approves device scope, security and safety risk, debug access, update and rollback, field monitoring, supplier exceptions, recovery, replacement, and retirement. Qualified hardware, firmware, safety, security, manufacturing, operations, privacy, and support owners must be assigned. Humans decide when a device may remain in service, be isolated, be updated, be replaced, or be safely decommissioned.

AI RESPONSIBILITIES AND BOUNDARIES

AI may inspect authorized schematics, manifests, firmware metadata, configurations, build records, vulnerability results, telemetry, and test evidence; identify likely weaknesses; draft threat models, controls, tests, and runbooks; and propose bounded remediation.

AI must preserve device, firmware, hardware, build, configuration, environment, source, time, and evidence boundaries. It must distinguish observed behavior, inferred risk, recommendation, executed action, and verified result, and must surface blind spots caused by unavailable hardware, offline operation, or missing telemetry.

AI must not alter devices, flash firmware, enable debug, extract secrets, infer authority, suppress safety signals, approve an update, declare a safe state, or execute containment without explicit delegation, authorization, audit, and human control.

APPLICABLE EXISTING AGENT ROLES

Architect, Embedded Engineer, Hardware Engineer, Security Auditor, Safety Reviewer, Researcher, Observer, Implementer, Tester, Verifier, Red Team, Governance Reviewer, Documentation Writer, Memory Curator, and User Experience Reviewer. Select roles proportionally and preserve their Section 02 contracts.

REQUIRED ACTIVITIES

1. Establish the device population, hardware and firmware versions, environments, interfaces, users, operators, safety effects, and lifecycle scope.
2. Inventory components, firmware, dependencies, trust roots, signing, keys, debug paths, provisioning, update, telemetry, and supplier boundaries.
3. Map trust boundaries and threats for physical access, tampering, cloning, extraction, fault injection, malicious peripherals, and supply-chain change.
4. Define least privilege, secure boot or equivalent trust establishment, signed updates, debug control, data minimization, logging, and safe-state behavior.
5. Design offline operation, power loss, network change, interrupted update, clock drift, degraded sensors, failed actuators, and recovery behavior.
6. Test normal, hostile, maintenance, migration, field, replacement, and disposal conditions and record limitations and residual risk.

HUMAN-AI INTERACTION REQUIREMENTS

- Show the exact device, firmware, hardware revision, configuration, authority, environment, and evidence for each conclusion.
- Require human review for flashing, debug access, key or credential handling, safety-affecting changes, field containment, update, replacement, and disposal.
- Keep a manual safe-halt, support, recovery, and evidence-preservation path when automation, telemetry, or a provider fails.
- Treat AI-generated threat hypotheses and test plans as proposals until verified against the actual device and declared threat scope.

ARCHITECTURE AND SYSTEM IMPLICATIONS

- Separate hardware, boot, firmware, application, service, network, physical, manufacturing, maintenance, and operator trust boundaries.
- Bind identity and update authority to device, version, hardware state, environment, and purpose; prevent rollback and unauthorized cloning where required.
- Minimize local data and define protection for storage, logs, caches, debug output, backups, interfaces, and disposal.
- Design recovery independent of the failed component where practical, with safe halt, containment, known-good image, replacement, and manual control.
- Treat suppliers, components, tools, build systems, signing services, update providers, and field support as versioned dependencies.

CODEX/03_SECTIONS/198_EMBEDDED_SECURITY.txt

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show device identity, hardware and firmware version, posture, owner, location or environment at the permitted precision, safety impact, evidence freshness, findings, active update, and dependency health. Provide authorized controls to isolate, halt safely, update, roll back, recover, replace, preserve evidence, and retire. Explain impact, authority, evidence, and recovery for every consequential action.

REQUIRED OUTPUTS AND ARTIFACTS

- Device, hardware, firmware, component, supplier, trust-boundary, identity, key, interface, and data inventories.
- Threat model, security and safety requirements, secure boot and update design, debug policy, and recovery design.
- Build provenance, vulnerability, test, field-monitoring, incident, exception, acceptance, decision, evidence, and continuity records.
- Operating runbook, maintenance and support procedures, replacement plan, and secure disposal plan.

EVIDENCE REQUIREMENTS

Identify device, hardware revision, firmware and build, configuration, environment, method, coverage, actor, timestamp, result, owner, and limitation. Evidence may include reproducible tests, signed artifacts, configuration, logs, field observations, supplier records, and incident timelines. A certification or simulation proves only its bounded claim.

VERIFICATION AND ACCEPTANCE TESTS

- Verify boot trust, signing, rollback, debug control, identity, keys, permissions, data protection, update, and recovery.
- Exercise tampering, cloning, physical access, fault or power interruption, hostile interfaces, offline operation, network change, and failed update.
- Verify safe state, operator visibility, manual control, evidence preservation, replacement, restore, and disposal behavior.
- Reproduce findings and confirm that hardware, firmware, supplier, and configuration changes reopen affected evidence.

FAILURE STATES AND ANTI-PATTERNS

- Treating successful boot, device enrollment, a bench test, or certification as complete security evidence.
- Leaving debug ports, manufacturing credentials, test interfaces, recovery images, or update paths uncontrolled.
- Assuming connectivity, power, sensors, telemetry, provider availability, or a trusted physical environment.
- Storing secrets or sensitive data without a bounded purpose, protection, retention, and disposal path.
- Flashing or wiping a device without authority, safety review, recovery, and evidence preservation.

RECOVERY AND RECONSIDERATION

On suspected compromise, unsafe behavior, invalid evidence, failed update, lost trust root, or supplier change, preserve evidence, enter the approved safe state, isolate affected devices, and notify the owner. Use known-good firmware or hardware replacement, restore, re-provisioning, manual operation, or controlled retirement. Reassess safety, data, users, field impact, residual risk, and acceptance before service resumes.

COMPLETION CRITERIA

The exact devices, hardware, firmware, threats, interfaces, identities, controls, owners, evidence, tests, safe states, recovery, disposal, limitations, and reopening conditions are recorded. Status remains CONTENT-COMPLETE until independent verification and owner acceptance.

HANDOFF AND CONTINUITY REQUIREMENTS

Preserve baseline identity, component and supplier records, build and signing history, threat model, findings, exceptions, evidence, decisions, incidents, recovery, field communications, and open gaps. Hand off to Hardware, Embedded, Cryptography, Key Management, Vulnerability, Testing, Safety, Operations, Support, and Disposal owners.

RELATED CODEX SECTIONS

045-047 Security, Identity, and Privacy Architecture; 050 Safety Architecture; 058-060 Hardware, Embedded, and Firmware Engineering; 190 Application Security; 197 Mobile Security; 199 Hardware Security; 203-205 Cryptography, Keys, and Secrets; 231-254 Testing; 298 Field Operations; 379 Firmware Updates; 398-400 Disposal.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

Based on the Canonical Section Contract, shared governance, Sections 019-060, security and testing context, and the integration roadmap. Exact device classes, safety regimes, platforms, supplier controls, certification, jurisdictions, field telemetry, retention, recovery authority, and owner acceptance evidence remain unresolved until supplied.

199

SECTION 199 - HARDWARE SECURITY

CODEX/03_SECTIONS/199_HARDWARE_SECURITY.txt

SHA-256 cb1cf26eed191956d494d900eabd2fcff6c674ab64af79ea186a270e6d5189ce

7,122 BYTES / PRESERVED SOURCE IDENTITY

SECTION 199 — Hardware Security

STATUS: CONTENT-COMPLETE

PURPOSE

Protect hardware components, boards, manufacturing processes, physical interfaces, supply-chain integrity, device identity, and hardware-assisted trust across the lifecycle.

REQUIRED OUTCOME

A hardware-security baseline covering assets, suppliers, provenance, tamper resistance, debug and service access, trust roots, physical exposure, secure provisioning, monitoring, replacement, and disposal for the declared product and environment.

WHY THIS MATTERS

Hardware is difficult to patch after deployment and can expose secrets or bypass software controls. A trusted design can be undermined by counterfeit components, altered firmware, open debug ports, insecure manufacturing, untracked substitutions, or physical access that the threat model ignored.

APPLICABILITY

Apply when hardware, boards, chips, modules, peripherals, manufacturing, provisioning, service ports, physical enclosures, or component supply chains affect identity, confidentiality, integrity, availability, safety, or recovery.

NON-APPLICABILITY CONDITIONS

Record non-applicability only when no hardware asset, physical interface, component trust, supplier, manufacturing, device identity, or lifecycle behavior is affected and an approved exact baseline supports that conclusion.

PREREQUISITES AND DEPENDENCIES

Use hardware, embedded, firmware, cryptography, key, identity, safety, supplier, vulnerability, testing, operations, and disposal baselines. Identify component owners, procurement controls, bill of materials, manufacturing and provisioning facilities, service authority, and physical threat assumptions.

REQUIRED INPUTS

Hardware inventory, schematics, layouts, bill of materials, component sources, substitutions, trust anchors, manufacturing steps, provisioning records, interfaces, enclosure, service access, threat model, safety constraints, and disposal requirements.

HUMAN RESPONSIBILITIES AND AUTHORITY

Owners approve component sources, substitutions, physical access, debug and service policy, provisioning, residual risk, field response, replacement, and disposal. Hardware, manufacturing, supply-chain, security, safety, operations, and service authorities must be assigned.

AI RESPONSIBILITIES AND BOUNDARIES

AI may analyze authorized bills of materials, schematics, supplier records, configurations, test results, and provenance evidence; identify inconsistencies; and draft controls, inspections, and test plans. It must preserve component and revision identity and distinguish evidence from inference. It must not approve substitutions, alter provisioning, expose secrets, change device trust, or authorize physical intervention without delegation.

APPLICABLE EXISTING AGENT ROLES

Architect, Hardware Engineer, Embedded Engineer, Security Auditor, Supply Chain Analyst, Researcher, Observer, Implementer, Tester, Verifier, Governance Reviewer, Critic, Red Team, Documentation Writer, and Memory Curator.

REQUIRED ACTIVITIES

Inventory components and revisions; classify trust and criticality; verify provenance and substitutions; secure manufacturing and provisioning; control debug and service interfaces; assess tamper and physical threats; test identity and trust roots; monitor field changes; define replacement and disposal; record exceptions and evidence.

HUMAN-AI INTERACTION REQUIREMENTS

Show component, revision, supplier, facility, device, environment, and evidence boundaries. Require human approval for source changes, substitutions, provisioning, debug access, field containment, or disposal. Do not turn a parts database, scan, or AI recommendation into a trust decision without owner review.

ARCHITECTURE AND SYSTEM IMPLICATIONS

Separate component provenance, manufacturing, provisioning, device identity, firmware trust, service access, physical enclosure, and operational trust boundaries. Use tamper evidence or resistance where justified, protect trust roots, minimize exposed interfaces, and make component changes traceable and reversible where possible.

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show hardware identity, revision, component provenance, supplier, posture, debug state, evidence freshness, open findings, field population, and authorized controls to quarantine, inspect, replace, recover, or retire. Explain physical and safety impact before action.

REQUIRED OUTPUTS AND ARTIFACTS

Hardware asset and component inventory; provenance and substitution record; threat model; secure manufacturing and provisioning design; interface and debug policy; inspection and test results; exception, incident, replacement, disposal, decision, evidence, and continuity records.

EVIDENCE REQUIREMENTS

Identify device or component, revision, supplier, facility, source, method, environment, timestamp, result, owner, coverage, and limitation. Provenance, inspection, scan, certification, or bench evidence must state what it does not establish.

VERIFICATION AND ACCEPTANCE TESTS

Verify bill of materials, provenance, substitution approval, identity, trust anchors, debug control, interface exposure, tamper response, provisioning, service access, replacement, and disposal. Test representative variants and hostile physical conditions within authorized scope.

FAILURE STATES AND ANTI-PATTERNS

Counterfeit or untraceable parts, undocumented substitutions, shared manufacturing credentials, exposed debug ports, unprotected trust roots, trust based on appearance, and treating one inspected device as representative of an uncontrolled population.

RECOVERY AND RECONSIDERATION

Quarantine affected lots or devices, preserve component and manufacturing evidence, revoke compromised trust, stop unsafe deployment, and use approved inspection, replacement, re-provisioning, or retirement. Reopen on supplier, component, revision, facility, physical threat, or field-condition change.

COMPLETION CRITERIA

Hardware assets, components, suppliers, trust boundaries, provisioning, interfaces, threats, owners, evidence, tests, recovery, disposal, limitations, and reopening conditions are explicit. Status remains CONTENT-COMPLETE pending independent verification and owner acceptance.

HANDOFF AND CONTINUITY REQUIREMENTS

Preserve bill of materials, revision history, supplier decisions, provisioning records, findings, evidence, exceptions, field impact, recovery, replacement, and open gaps. Hand off to Embedded, Firmware, Supply Chain, Security Operations, Testing, Safety, Operations, and Disposal.

RELATED CODEX SECTIONS

058 Hardware Engineering; 059 Embedded Engineering; 060 Firmware Engineering; 198 Embedded Security; 203 Cryptography; 204 Key Management; 209 Vulnerability Management; 231-254 Testing; 350-357 Manufacturing and Logistics; 379 Firmware Updates; 398-400 Disposal.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

Based on the Canonical Section Contract, shared governance, hardware and embedded architecture, and the integration roadmap. Exact hardware classes, supplier requirements, tamper standards, certification, jurisdiction, field exposure, and acceptance evidence remain unresolved.

200

SECTION 200 - IDENTITY AND ACCESS MANAGEMENT

CODEX/03_SECTIONS/200_IDENTITY_AND_ACCESS_MANAGEMENT.txt

SHA-256 1cd43fc3f6b366dfd90de94fd4def9bed6466b3026373f603399ebbf8951655d

6,807 BYTES / PRESERVED SOURCE IDENTITY

SECTION 200 — Identity and Access Management

STATUS: CONTENT-COMPLETE

PURPOSE

Govern identities and access lifecycle for people, services, devices, workloads, agents, organizations, and external parties from creation through retirement.

REQUIRED OUTCOME

An identity and access model with authoritative sources, identity proofing, authentication dependency, authorization relationship, provisioning, review, delegation, privileged access, logging, revocation, recovery, and owner accountability.

WHY THIS MATTERS

Access failures arise from stale identities, unclear ownership, excessive privilege, broken federation, service accounts, orphaned devices, and delayed removal. A successful login is not proof that the identity is real, current, entitled, or acting for the right purpose.

APPLICABILITY

Apply whenever a person, service, device, workload, agent, supplier, or organization can access information, invoke a capability, make a decision, or affect a protected resource.

NON-APPLICABILITY CONDITIONS

Record non-applicability only when no identity, access, delegation, protected resource, service action, or lifecycle state is affected and an approved exact baseline covers the change.

PREREQUISITES AND DEPENDENCIES

Use identity, authentication, authorization, privacy, security, data, application, platform, operations, legal, and governance baselines. Identify authoritative identity sources, ownership, populations, tenants, trust relationships, resource inventory, and access-review authority.

REQUIRED INPUTS

Identity types, attributes, proofing, lifecycle events, authoritative sources, federation, authentication methods, roles, policies, resources, environments, tenants, privileged paths, logs, review cadence, exceptions, and recovery obligations.

HUMAN RESPONSIBILITIES AND AUTHORITY

Owners define identity purpose, resource ownership, access policy, acceptable risk, privileged roles, delegation, review, exceptions, suspension, recovery, and retirement. Humans approve identity proofing, sensitive access, privilege, cross-tenant trust, automated decisions, and disputed or harmful outcomes.

AI RESPONSIBILITIES AND BOUNDARIES

AI may inspect authorized identity metadata, access records, policy definitions, lifecycle signals, and review evidence; identify orphaned or inconsistent records; draft mappings and review queues; and recommend least-privilege changes. It must preserve identity, tenant, purpose, resource, source, time, and confidence boundaries. It must not create, merge, impersonate, provision, revoke, grant, or infer identity authority without explicit delegation and human approval.

APPLICABLE EXISTING AGENT ROLES

Architect, Identity Engineer, Security Auditor, Governance Reviewer, Researcher, Analyst, Observer, Implementer, Tester, Verifier, Critic, Coordinator, Documentation Writer, Memory Curator, and User Experience Reviewer.

REQUIRED ACTIVITIES

Inventory identity classes and authoritative sources; define proofing and attributes; model lifecycle and ownership; map access relationships; design federation and delegation; separate privileged access; establish reviews, logging, revocation, recovery, privacy, support, and retirement; test drift and failure; record decisions and exceptions.

HUMAN-AI INTERACTION REQUIREMENTS

Show identity type, source, owner, tenant, resource, purpose, authority, freshness, and evidence for every material recommendation. Require human review for sensitive access, privilege, identity merge, suspension, revocation, cross-boundary sharing, and appeals. Preserve manual recovery and accessible explanations.

ARCHITECTURE AND SYSTEM IMPLICATIONS

Separate identity proofing, authentication, authorization, resource ownership, policy decision, policy enforcement, audit, lifecycle, and recovery. Use stable identifiers, explicit tenancy, least privilege, separation of duties, short-lived authority where appropriate, and fail-closed behavior for protected actions.

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show identity inventory, owner, source, lifecycle state, active sessions, privileges, resources, policy, review status, evidence freshness, anomalies, and impact. Provide authorized approve, deny, suspend, revoke, recover, delegate, appeal, and retire controls with reason and audit trail.

REQUIRED OUTPUTS AND ARTIFACTS

Identity taxonomy; authoritative-source and lifecycle map; access and role model; federation and delegation design; privileged-access model; review, logging, revocation, recovery, exception, test, decision, evidence, and handoff records.

EVIDENCE REQUIREMENTS

Identify subject, identity type, source, owner, tenant, resource, purpose, policy version, method, time, actor, result, and limitation. A directory record or successful login proves only its bounded claim.

VERIFICATION AND ACCEPTANCE TESTS

Verify joiner, mover, leaver, suspension, recovery, federation, privilege, delegation, tenant isolation, policy enforcement, logging, review, and revocation. Test stale source, duplicate identity, provider outage, clock skew, lost device, and disputed access.

FAILURE STATES AND ANTI-PATTERNS

Shared accounts, orphaned identities, implicit trust, unowned resources, permanent privilege, directory truth assumed without source validation, and automated provisioning without authority or rollback.

RECOVERY AND RECONSIDERATION

Freeze affected changes, preserve evidence, revoke or narrow unsafe access, notify owners, and use approved recovery, source reconciliation, manual review, or prior policy. Restore only after identity, authority, privacy, and user impact are reassessed.

COMPLETION CRITERIA

Identity classes, sources, owners, resources, lifecycle, access, privilege, delegation, reviews, evidence, recovery, exceptions, and reopening conditions are explicit. Status remains CONTENT-COMPLETE pending independent verification and owner acceptance.

HANDOFF AND CONTINUITY REQUIREMENTS

Preserve identity and resource inventories, source precedence, policy versions, access decisions, reviews, incidents, evidence, exceptions, and open gaps. Hand off to Authentication, Authorization, Privacy, Security Operations, Application, Platform, Support, and Records owners.

RELATED CODEX SECTIONS

046 Identity Architecture; 047 Privacy Architecture; 201 Authentication Engineering; 202 Authorization Engineering; 205 Secrets Management; 206 Security Operations; 214 Incident Response; 231-254 Testing; 301-330 Operations.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

Based on the Canonical Section Contract, shared governance, identity and security architecture, and the integration roadmap. Exact identity authorities, proofing levels, legal requirements, federation partners, tenant model, retention, accessibility, and owner acceptance remain unresolved.

201

SECTION 201 - AUTHENTICATION ENGINEERING

CODEX/03_SECTIONS/201_AUTHENTICATION_ENGINEERING.txt

SHA-256 4385c48068e043ab960b81a7629c2429d5ab4452d57153d526dedb46182f2494

6,810 BYTES / PRESERVED SOURCE IDENTITY

SECTION 201 — Authentication Engineering

STATUS: CONTENT-COMPLETE

PURPOSE

Engineer trustworthy authentication that establishes the assurance, binding, freshness, and session context required before an identity is allowed to request access.

REQUIRED OUTCOME

An authentication design covering assurance levels, authenticators, enrollment, recovery, phishing and replay resistance, federation, session management, step-up, failure handling, logging, user support, and retirement.

WHY THIS MATTERS

Authentication can fail through stolen credentials, weak recovery, session theft, phishing, replay, device compromise, clock or provider failure, and poor user comprehension. A successful challenge proves only what the challenge and binding actually establish.

APPLICABILITY

Apply whenever an identity must be established before access, transaction, administration, delegation, account recovery, or other consequential action.

NON-APPLICABILITY CONDITIONS

Record non-applicability only when no identity assertion, authenticator, session, recovery, federation, or protected action is affected and an approved exact baseline applies.

PREREQUISITES AND DEPENDENCIES

Use identity, authorization, privacy, cryptography, key, device, application, platform, accessibility, support, and incident baselines. Define identity source, assurance target, user population, authenticators, provider, protected actions, and recovery authority.

REQUIRED INPUTS

Identity types, assurance levels, authenticators, enrollment, proofing, device binding, federation, session rules, step-up triggers, recovery, rate limits, telemetry, user journeys, accessibility needs, threats, and acceptance criteria.

HUMAN RESPONSIBILITIES AND AUTHORITY

Owners approve assurance levels, acceptable authenticators, recovery risk, step-up, provider trust, lockout, support verification, exceptions, and user communication. Humans decide disputed identity, high-impact recovery, emergency access, and residual risk.

AI RESPONSIBILITIES AND BOUNDARIES

AI may inspect authorized authentication configuration, event records, test results, and user-flow evidence; identify patterns; draft controls, tests, and explanations; and propose bounded improvements. It must preserve subject, authenticator, provider, device, session, time, and source boundaries. It must not authenticate a person, reset credentials, bypass a challenge, approve recovery, or label a user fraudulent without delegated authority and human review.

APPLICABLE EXISTING AGENT ROLES

Architect, Identity Engineer, Security Auditor, User Experience Reviewer, Accessibility Reviewer, Researcher, Tester, Verifier, Governance Reviewer, Observer, Critic, Implementer, Documentation Writer, and Memory Curator.

REQUIRED ACTIVITIES

Define assurance and threat scope; select authenticators; design enrollment, binding, federation, session, step-up, recovery, lockout, rate limiting, notification, logging, support, and retirement; test phishing, replay, credential theft, provider loss, offline use, accessibility, and user recovery; record evidence and exceptions.

HUMAN-AI INTERACTION REQUIREMENTS

Show the claimed assurance, authenticator, provider, device, session, risk signal, evidence, and limitation. Require human review for high-impact recovery, emergency access, lockout reversal, provider change, and suspected fraud. Preserve accessible alternatives and appeal without weakening protected actions.

ARCHITECTURE AND SYSTEM IMPLICATIONS

Separate identity proofing, authenticator enrollment, challenge, assertion, session, authorization, recovery, notification, and audit. Use replay resistance, secure binding, short-lived sessions, explicit reauthentication, rate limits, safe error messages, and fail-safe recovery that does not become an attack bypass.

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show authentication methods, assurance, devices, sessions, provider state, recovery state, recent events, evidence freshness, lockouts, and active risks. Provide authorized revoke, reauthenticate, recover, report, appeal, and support controls with clear effect and audit.

REQUIRED OUTPUTS AND ARTIFACTS

Authentication assurance and threat model; authenticator and enrollment design; session and step-up rules; recovery and support procedures; user and accessibility flows; test, event, exception, decision, evidence, and continuity records.

EVIDENCE REQUIREMENTS

Identify subject, authenticator, provider, device, challenge, session, environment, policy version, method, timestamp, result, and limitation. A login event proves only that the declared mechanism accepted the declared assertion.

VERIFICATION AND ACCEPTANCE TESTS

Verify enrollment, binding, phishing and replay resistance, session expiry, revocation, step-up, recovery, lockout, rate limits, federation, accessibility, logging, and provider failure. Test credential theft, device loss, clock skew, duplicate identity, and support social engineering within authorized scope.

FAILURE STATES AND ANTI-PATTERNS

Password-only high-risk access, shared authenticators, weak recovery, reusable sessions, silent provider trust, informative errors that aid guessing, lockout denial of service, and treating MFA presence as sufficient assurance for every action.

RECOVERY AND RECONSIDERATION

Preserve events, narrow affected sessions, notify the owner and user as appropriate, and use approved reauthentication, recovery, provider failover, or manual review. Reassess identity, user harm, privacy, and authorization before restoring access. Reopen on authenticator, provider, population, threat, or assurance change.

COMPLETION CRITERIA

Assurance, authenticators, enrollment, sessions, step-up, recovery, support, accessibility, evidence, tests, owners, exceptions, and reopening conditions are explicit. Status remains CONTENT-COMPLETE pending independent verification and owner acceptance.

HANDOFF AND CONTINUITY REQUIREMENTS

Preserve assurance and policy versions, authenticator inventory, provider agreements, event and recovery records, findings, evidence, exceptions, and open gaps. Hand off to IAM, Authorization, Cryptography, Key Management, Security Operations, Support, Testing, and Incident Response.

RELATED CODEX SECTIONS

046 Identity Architecture; 047 Privacy Architecture; 200 Identity and Access Management; 202 Authorization Engineering; 203 Cryptography; 204 Key Management; 206 Security Operations; 214 Incident Response; 231-254 Testing.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

Based on the Canonical Section Contract, shared governance, identity and security architecture, and the integration roadmap. Exact assurance levels, authenticators, provider contracts, recovery law, accessibility requirements, user population, and acceptance evidence remain unresolved.

202

SECTION 202 - AUTHORIZATION ENGINEERING

CODEX/03_SECTIONS/202_AUTHORIZATION_ENGINEERING.txt

SHA-256 abfe7af1174c7d18817f141cc91f1dd17b3570c8a6841d0cc2c3d94bd3980743

6,553 BYTES / PRESERVED SOURCE IDENTITY

SECTION 202 — Authorization Engineering

STATUS: CONTENT-COMPLETE

PURPOSE

Engineer decisions that allow, deny, limit, delegate, or review access to a resource or action using explicit identity, purpose, context, policy, and authority.

REQUIRED OUTCOME

An authorization model with resource ownership, actions, subjects, policy rules, context, delegation, separation of duties, enforcement points, denial behavior, decision evidence, review, and change control.

WHY THIS MATTERS

Authentication alone does not establish that a subject may perform a particular action on a particular resource. Authorization fails through broad roles, confused deputy behavior, stale context, client-side enforcement, default allow, missing tenant isolation, and unreviewed delegation.

APPLICABILITY

Apply whenever an identity, service, device, workload, agent, or user can read, create, change, execute, approve, share, delete, administer, or otherwise affect a resource or decision.

NON-APPLICABILITY CONDITIONS

Record non-applicability only when no protected resource, action, identity relationship, delegation, or policy decision is affected and an approved exact baseline covers the scope.

PREREQUISITES AND DEPENDENCIES

Use IAM, authentication, privacy, data, application, platform, tenant, safety, governance, and audit baselines. Identify resources, owners, actions, policy source, enforcement points, context, emergency paths, and review authority.

REQUIRED INPUTS

Subjects, identities, resources, owners, actions, roles, attributes, purpose, context, tenants, environments, policy rules, obligations, delegation, exceptions, logs, and acceptance criteria.

HUMAN RESPONSIBILITIES AND AUTHORITY

Owners define resource ownership, protected actions, least privilege, separation of duties, delegation, emergency access, exception, review, and acceptance. Humans approve high-impact grants, policy meaning, cross-boundary access, break-glass use, and disputed outcomes.

AI RESPONSIBILITIES AND BOUNDARIES

AI may inspect authorized policies, access decisions, resource metadata, and review evidence; identify excessive or inconsistent privilege; draft policy tests and explanations; and propose bounded least-privilege changes. It must preserve subject, resource, action, context, policy, tenant, and time boundaries. It must not grant, deny, rewrite, or silently bypass policy for consequential access without explicit delegation and human control.

APPLICABLE EXISTING AGENT ROLES

Architect, Identity Engineer, Security Auditor, Governance Reviewer, Analyst, Researcher, Observer, Implementer, Tester, Verifier, Critic, Red Team, Documentation Writer, and Memory Curator.

REQUIRED ACTIVITIES

Inventory resources and actions; assign owners; define subjects, roles, attributes, purpose, context, tenancy, and separation of duties; design decision and enforcement points; define deny, delegation, emergency, review, logging, recovery, and change behavior; test bypass and drift; record evidence and exceptions.

HUMAN-AI INTERACTION REQUIREMENTS

Show the subject, resource, action, policy version, context, decision, authority, evidence, and consequence. Require human review for grants, policy changes, break-glass, cross-tenant access, high-impact denial, and appeals. Make decisions understandable and auditable without revealing protected policy details unnecessarily.

ARCHITECTURE AND SYSTEM IMPLICATIONS

Separate policy administration, policy decision, policy enforcement, resource ownership, identity, audit, and appeal. Enforce server-side at every trust boundary, default deny protected actions, make context freshness explicit, prevent confused deputy behavior, and ensure failover cannot silently widen access.

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show resource owner, subject, effective privileges, policy source, context, active delegation, decision history, evidence freshness, anomalies, and impact. Provide authorized grant, deny, revoke, simulate, review, appeal, emergency, and retire controls with durable audit.

REQUIRED OUTPUTS AND ARTIFACTS

Resource and action inventory; authorization model; policy and delegation catalog; enforcement and decision design; separation-of-duties and emergency model; test, review, exception, decision, evidence, and continuity records.

EVIDENCE REQUIREMENTS

Identify subject, resource, action, context, tenant, policy and version, decision point, enforcement result, actor, time, method, and limitation. A UI state or client-side check proves no server-side authorization.

VERIFICATION AND ACCEPTANCE TESTS

Verify allow and deny, least privilege, tenant isolation, object and function checks, delegation, separation of duties, context expiry, emergency access, logging, revocation, and failover. Test tampered requests, stale roles, confused deputy, race conditions, and provider loss.

FAILURE STATES AND ANTI-PATTERNS

Default allow, client-only checks, wildcard roles, shared service identity, unowned resources, implicit inheritance, stale context, unbounded break-glass, and access decisions with no owner or evidence.

RECOVERY AND RECONSIDERATION

Freeze affected policy changes, revoke unsafe grants, preserve decisions and context, notify owners, and use prior validated policy or manual review. Reassess user harm, continuity, obligations, and downstream effects before restoring access. Reopen on resource, action, identity, tenant, policy, or threat change.

COMPLETION CRITERIA

Subjects, resources, actions, owners, policies, context, enforcement, delegation, review, evidence, recovery, exceptions, and reopening conditions are explicit. Status remains CONTENT-COMPLETE pending independent verification and owner acceptance.

HANDOFF AND CONTINUITY REQUIREMENTS

Preserve policy versions, resource ownership, decisions, delegations, reviews, events, exceptions, evidence, incidents, and open gaps. Hand off to IAM, Authentication, Application, Data, Platform, Security Operations, Governance, Testing, and Support.

RELATED CODEX SECTIONS

046 Identity Architecture; 047 Privacy Architecture; 200 Identity and Access Management; 201 Authentication Engineering; 205 Secrets Management; 206 Security Operations; 214 Incident Response; 231-254 Testing.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

Based on the Canonical Section Contract, shared governance, identity and security architecture, and the integration roadmap. Exact policy language, resource classification, tenant model, emergency authority, legal obligations, and acceptance evidence remain unresolved.

203

SECTION 203 - CRYPTOGRAPHY

CODEX/03_SECTIONS/203_CRYPTOGRAPHY.txt

SHA-256 ada575b4efcbbf9b6fdcc7e07a6eabf0fa74cc950d3db0eeea94021423e83132

6,934 BYTES / PRESERVED SOURCE IDENTITY

SECTION 203 — Cryptography

STATUS: CONTENT-COMPLETE

PURPOSE

Select, apply, verify, and retire cryptographic protections that preserve confidentiality, integrity, authenticity, non-repudiation where required, and controlled recovery for the declared data and trust scope.

REQUIRED OUTCOME

A cryptographic architecture with protection goals, algorithms and protocols, randomness, parameters, key dependencies, trust boundaries, data states, implementation constraints, crypto-agility, verification, migration, and failure handling.

WHY THIS MATTERS

Cryptography can create false confidence when the wrong property, algorithm, mode, key lifecycle, implementation, or trust assumption is used. Strong primitives do not repair poor key management, unauthenticated metadata, weak randomness, unsafe downgrade, or unverified migration.

APPLICABILITY

Apply when information, identity, communication, software, hardware, transactions, or evidence requires confidentiality, integrity, authenticity, origin binding, controlled disclosure, or tamper detection.

NON-APPLICABILITY CONDITIONS

Record non-applicability only when no protected property, cryptographic protocol, key, trust anchor, signature, encrypted data, or migration behavior is affected and an approved exact baseline supports it.

PREREQUISITES AND DEPENDENCIES

Use data classification, threat model, identity, key, secrets, application, network, hardware, compliance, retention, and recovery baselines. Define security goals, adversary, data states, trust boundaries, interoperability, performance, and recovery authority.

REQUIRED INPUTS

Protection goals, data and protocol inventory, algorithms, modes, parameters, libraries, platforms, randomness, keys, certificates, trust anchors, users, jurisdictions, performance, retention, migration, and acceptance requirements.

HUMAN RESPONSIBILITIES AND AUTHORITY

Owners and qualified security authorities approve cryptographic policy, algorithms, parameters, trust anchors, exceptions, export or regulatory handling, migration, decryption recovery, and retirement. Humans accept residual risk and decide when a protection is no longer adequate.

AI RESPONSIBILITIES AND BOUNDARIES

AI may inspect authorized cryptographic configurations, dependency versions, protocol traces, certificates, and test evidence; identify known mismatches; draft inventories, tests, and migration options; and explain bounded behavior. It must not invent security strength, generate or expose production keys, choose policy without authority, weaken protection, or declare compliance from a library name or successful handshake.

APPLICABLE EXISTING AGENT ROLES

Architect, Cryptography Engineer, Security Auditor, Researcher, Analyst, Implementer, Tester, Verifier, Governance Reviewer, Critic, Red Team, Documentation Writer, and Memory Curator.

REQUIRED ACTIVITIES

Map protection goals and data states; select approved primitives and protocols; define parameters and trust anchors; verify randomness and implementation; bind identities and metadata; design downgrade and failure behavior; test interoperability and misuse; plan crypto-agility, migration, recovery, and retirement; record decisions and evidence.

HUMAN-AI INTERACTION REQUIREMENTS

Show protection goal, algorithm, mode, parameter, implementation, key dependency, trust anchor, version, environment, evidence, and limitation. Require human review for policy, key, trust, downgrade, migration, decryption, and exception decisions. Never place production secrets in prompts, logs, or generated artifacts.

ARCHITECTURE AND SYSTEM IMPLICATIONS

Separate cryptographic policy, implementation, key management, certificate or trust authority, data, protocol, audit, recovery, and retirement. Authenticate context and metadata, prevent downgrade, use approved randomness and libraries, minimize custom cryptography, and make algorithm and key changes versioned and observable.

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show protected asset, goal, algorithm, version, trust anchor, key state, evidence freshness, findings, migration state, and authorized controls to rotate, revoke, re-encrypt, restrict, recover, and retire. Explain data and operational impact before action.

REQUIRED OUTPUTS AND ARTIFACTS

Cryptographic policy; protection and data-state map; algorithm and protocol inventory; trust-boundary and dependency model; implementation and misuse tests; migration, exception, recovery, decision, evidence, and continuity records.

EVIDENCE REQUIREMENTS

Identify asset, protection goal, protocol, algorithm, mode, parameters, implementation, version, key or trust dependency, environment, method, result, owner, and limitation. A successful handshake or encrypted file proves only its declared property and configuration.

VERIFICATION AND ACCEPTANCE TESTS

Verify confidentiality, integrity, authenticity, randomness, parameter validation, identity binding, downgrade resistance, error handling, interoperability, key rotation, revocation, migration, recovery, and logging. Test wrong keys, altered context, replay, truncation, provider loss, and unsupported versions.

FAILURE STATES AND ANTI-PATTERNS

Custom cryptography, obsolete or unapproved primitives, unauthenticated encryption, hard-coded keys, weak randomness, silent downgrade, missing context binding, unverifiable certificates, and treating encryption at rest as complete protection.

RECOVERY AND RECONSIDERATION

Preserve protected evidence, isolate affected protocols or data, revoke compromised trust, rotate or re-encrypt under approved authority, and use controlled legacy read paths only when risk is accepted. Reassess exposure, availability, retention, and recovery before restoring normal operation.

COMPLETION CRITERIA

Goals, assets, threats, algorithms, parameters, implementations, trust, keys, owners, tests, migration, recovery, evidence, limitations, and reopening conditions are explicit. Status remains CONTENT-COMPLETE pending independent verification and owner acceptance.

HANDOFF AND CONTINUITY REQUIREMENTS

Preserve policy and implementation versions, algorithm decisions, trust anchors, findings, exceptions, evidence, migration state, incidents, and open gaps. Hand off to Key Management, Secrets, Identity, Application, Network, Hardware, Security Operations, Testing, and Records.

RELATED CODEX SECTIONS

045 Security Architecture; 046 Identity Architecture; 200-202 Identity, Authentication, and Authorization; 204 Key Management; 205 Secrets Management; 206 Security Operations; 231-254 Testing; 388 Version Management; 391-395 Data Lifecycle.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

Based on the Canonical Section Contract, shared governance, security architecture, and the integration roadmap. Exact algorithms, assurance levels, jurisdictions, interoperability, future migration, hardware support, retention, and acceptance authority remain unresolved.

204

SECTION 204 - KEY MANAGEMENT

CODEX/03_SECTIONS/204_KEY_MANAGEMENT.txt

SHA-256 060113c43066455a5e5a9d6bf2a4be5dc548b40a1451168febf50dc7e1b34cd6

6,594 BYTES / PRESERVED SOURCE IDENTITY

SECTION 204 — Key Management

STATUS: CONTENT-COMPLETE

PURPOSE

Govern cryptographic keys through generation, provisioning, activation, use, rotation, backup, recovery, revocation, archival, destruction, and retirement.

REQUIRED OUTCOME

A key lifecycle and trust model identifying key classes, owners, purpose, algorithms, custody, access, state transitions, separation of duties, hardware or service protection, evidence, recovery, and destruction authority.

WHY THIS MATTERS

Keys are operational authority and protected assets. Lost, exposed, misused, stale, duplicated, or undeleted keys can make encrypted information unavailable, permit impersonation, invalidate evidence, or leave exposure after a system is retired.

APPLICABILITY

Apply when cryptographic keys, certificates, signing identities, tokens, trust anchors, hardware roots, or derived secrets protect data, identity, software, devices, communications, or decisions.

NON-APPLICABILITY CONDITIONS

Record non-applicability only when no key, trust anchor, cryptographic operation, certificate, signing identity, recovery, or destruction behavior is affected and an approved exact baseline covers the work.

PREREQUISITES AND DEPENDENCIES

Use cryptography, identity, secrets, hardware, application, data, retention, recovery, compliance, and operations baselines. Define key owners, purpose, classification, algorithm, custody, consumers, availability, recovery, and destruction obligations.

REQUIRED INPUTS

Key inventory, classes, owners, purpose, algorithm, state, generation, storage, access, rotation, escrow or backup, recovery, revocation, consumers, dependencies, logs, retention, and acceptance criteria.

HUMAN RESPONSIBILITIES AND AUTHORITY

Owners approve key purpose, custody, access, rotation, recovery, escrow, revocation, exceptions, and destruction. Separate administration, use, approval, audit, and recovery where consequence warrants. Humans decide whether a key may be recovered, retained, or destroyed.

AI RESPONSIBILITIES AND BOUNDARIES

AI may inspect authorized key metadata, lifecycle records, certificate inventories, rotation events, and test evidence; identify stale or inconsistent state; draft inventories, controls, and tests; and propose bounded remediation. It must never request, reveal, generate, copy, store, rotate, revoke, recover, or destroy production key material without explicit authorized tooling and human control.

APPLICABLE EXISTING AGENT ROLES

Architect, Cryptography Engineer, Key Management Engineer, Security Auditor, Governance Reviewer, Implementer, Tester, Verifier, Researcher, Analyst, Critic, Documentation Writer, and Memory Curator.

REQUIRED ACTIVITIES

Classify keys and assign owners; define state transitions; select generation and storage controls; enforce separation of duties; bind keys to purpose and identity; design rotation, revocation, backup, recovery, archival, destruction, audit, migration, and incident response; test failure and restore; record exceptions.

HUMAN-AI INTERACTION REQUIREMENTS

Keep key material out of prompts, logs, diagnostics, and generated documents. Show key identifier, purpose, owner, state, consumer, policy version, evidence, and limitation without exposing secret material. Require human approval for recovery, revocation, destruction, escrow, and emergency use.

ARCHITECTURE AND SYSTEM IMPLICATIONS

Separate key administration, cryptographic use, storage, hardware security, backup, recovery, audit, certificate authority, and application data. Use non-exportable protection where justified, least privilege, dual control, key versioning, dependency discovery, and explicit behavior when the key service is unavailable.

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show key class, identifier, purpose, owner, state, age, consumers, rotation and expiry, evidence freshness, incidents, dependencies, and authorized rotate, revoke, recover, re-encrypt, archive, and destroy controls. Never render secret material.

REQUIRED OUTPUTS AND ARTIFACTS

Key taxonomy and inventory; lifecycle and custody model; generation, storage, rotation, recovery, revocation, archival, destruction, and migration procedures; access, audit, test, exception, decision, evidence, and continuity records.

EVIDENCE REQUIREMENTS

Identify key class and identifier, purpose, owner, state, algorithm, version, service or device, method, time, actor, result, and limitation. Evidence must prove control behavior without exposing key material; a key record alone does not prove safe custody or use.

VERIFICATION AND ACCEPTANCE TESTS

Verify generation, entropy, custody, access, use binding, rotation, revocation, expiry, backup, restore, failover, audit, destruction, and consumer migration. Test unavailable key service, lost recovery path, stale certificate, duplicate key, unauthorized export, and emergency procedure.

FAILURE STATES AND ANTI-PATTERNS

Hard-coded or shared keys, unowned keys, indefinite lifetime, uncontrolled export, backup without protection, recovery by one person, rotation that breaks consumers, and destroying keys without retention or legal review.

RECOVERY AND RECONSIDERATION

Preserve key state and evidence, isolate affected consumers, revoke or rotate compromised keys, use approved recovery or prior version, and notify owners. Re-encrypt or restrict data where required. Reassess availability, exposure, retention, and destruction before resuming.

COMPLETION CRITERIA

Key classes, owners, purpose, lifecycle, custody, access, consumers, recovery, destruction, evidence, tests, exceptions, and reopening conditions are explicit. Status remains CONTENT-COMPLETE pending independent verification and owner acceptance.

HANDOFF AND CONTINUITY REQUIREMENTS

Preserve identifiers and metadata, not secret material, along with lifecycle decisions, consumer dependencies, rotations, incidents, evidence, exceptions, recovery, and open gaps. Hand off to Cryptography, Identity, Secrets, Application, Hardware, Operations, Records, and Security Operations.

RELATED CODEX SECTIONS

045 Security Architecture; 046 Identity Architecture; 198-199 Embedded and Hardware Security; 200-203 IAM, Authentication, Authorization, and Cryptography; 205 Secrets Management; 206 Security Operations; 391-395 Data Lifecycle.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

Based on the Canonical Section Contract, shared governance, cryptographic and identity architecture, and the integration roadmap. Exact custody, hardware, escrow, recovery, regulatory, retention, algorithm, and destruction requirements remain unresolved.

205

SECTION 205 - SECRETS MANAGEMENT

CODEX/03_SECTIONS/205_SECRETS_MANAGEMENT.txt

SHA-256 9b3bb8c17bea07ff8cfb203332481ed3224e18bc1134af56bb6ac8098a704af3

6,860 BYTES / PRESERVED SOURCE IDENTITY

SECTION 205 — Secrets Management

STATUS: CONTENT-COMPLETE

PURPOSE

Control non-public credentials, tokens, passwords, connection material, certificates, signing material, configuration secrets, and other sensitive values across creation, use, storage, rotation, exposure, recovery, and retirement.

REQUIRED OUTCOME

A secrets lifecycle with inventory, classification, ownership, approved storage, retrieval, least privilege, injection, rotation, detection, redaction, incident response, recovery, and destruction for every declared environment and consumer.

WHY THIS MATTERS

Secrets are frequently copied into code, logs, images, tickets, prompts, backups, and developer machines. Exposure can create immediate access while rotation can silently break services. A secret store does not prove that consumers, replicas, caches, or historical copies are controlled.

APPLICABILITY

Apply whenever a non-public value can authenticate, authorize, decrypt, sign, connect, identify, configure, or otherwise grant access to a system, service, device, data store, provider, or person.

NON-APPLICABILITY CONDITIONS

Record non-applicability only when no sensitive value, credential, token, certificate, connection, signing material, or secret lifecycle is affected and an approved exact baseline applies.

PREREQUISITES AND DEPENDENCIES

Use IAM, authentication, authorization, cryptography, key, application, platform, source-control, build, deployment, logging, privacy, incident, retention, and operations baselines. Identify owners, consumers, environments, providers, and emergency access authority.

REQUIRED INPUTS

Secret inventory, type, owner, purpose, consumers, environments, source, storage, injection, permissions, lifetime, rotation, detection, redaction, backups, logs, exposure history, recovery, and destruction requirements.

HUMAN RESPONSIBILITIES AND AUTHORITY

Owners approve secret purpose, storage, access, rotation, emergency retrieval, exceptions, exposure response, and destruction. Humans authorize recovery and decide whether a suspected exposure requires service isolation, user notification, or legal response.

AI RESPONSIBILITIES AND BOUNDARIES

AI may inspect authorized metadata, configuration references, redacted logs, dependency records, and secret lifecycle evidence; identify likely exposure paths; draft remediation and tests; and explain bounded impact. AI must not request, print, store, copy, infer, or place secret values into prompts, code, logs, reports, or memory. It must not rotate, revoke, retrieve, or distribute secrets without explicit authorized tooling and human control.

APPLICABLE EXISTING AGENT ROLES

Security Auditor, Identity Engineer, Cryptography Engineer, Key Management Engineer, Architect, Implementer, Tester, Verifier, Governance Reviewer, Researcher, Critic, Documentation Writer, and Memory Curator.

REQUIRED ACTIVITIES

Discover and classify secrets; assign owners and consumers; remove hard-coded values; select storage and injection; minimize exposure; enforce access and redaction; rotate and revoke; scan code, artifacts, logs, and backups; handle incidents; test failure and recovery; retire and destroy; record exceptions and evidence.

HUMAN-AI INTERACTION REQUIREMENTS

Use metadata, fingerprints, redaction, or placeholders rather than secret values. Show owner, purpose, consumer, environment, age, state, evidence, and impact. Require human review for exposure response, emergency retrieval, rotation, revocation, notification, and destruction.

ARCHITECTURE AND SYSTEM IMPLICATIONS

Separate secret authority, storage, retrieval, injection, application use, audit, rotation, detection, backup, and destruction. Prefer short-lived, scoped values; avoid secrets in source, images, command lines, telemetry, prompts, and crash artifacts; define behavior when the store is unavailable.

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show secret identifier, class, owner, purpose, consumers, environment, age, rotation, exposure status, evidence freshness, and authorized rotate, revoke, quarantine, recover, and destroy actions without rendering the value.

REQUIRED OUTPUTS AND ARTIFACTS

Secret taxonomy and inventory; storage and injection design; access and redaction policy; rotation and revocation procedures; exposure response; scan and test results; exception, decision, evidence, recovery, and continuity records.

EVIDENCE REQUIREMENTS

Identify secret class and non-sensitive identifier, owner, purpose, consumer, environment, storage, policy version, method, time, result, and limitation. Evidence must never reproduce the value; a clean scan proves only its coverage and detection rules.

VERIFICATION AND ACCEPTANCE TESTS

Verify source, image, log, prompt, backup, runtime, and developer-workstation exposure controls; access restriction; injection; rotation; revocation; redaction; audit; outage behavior; and recovery. Use synthetic test values where testing requires a secret.

FAILURE STATES AND ANTI-PATTERNS

Hard-coded credentials, shared long-lived tokens, secrets in logs or tickets, broad read access, untracked copies, rotation without consumer coordination, false-positive scans that train teams to ignore findings, and secret values included in AI context.

RECOVERY AND RECONSIDERATION

Treat suspected exposure as potentially real until bounded evidence shows otherwise. Preserve forensic records without copying the value, revoke or rotate, isolate consumers, remove replicas, notify owners, and validate replacement. Reassess service continuity, user impact, legal duties, backups, and retention before closure.

COMPLETION CRITERIA

Secrets, owners, consumers, environments, storage, access, injection, rotation, detection, recovery, destruction, evidence, tests, exceptions, and reopening conditions are explicit. Status remains CONTENT-COMPLETE pending independent verification and owner acceptance.

HANDOFF AND CONTINUITY REQUIREMENTS

Preserve non-sensitive identifiers, lifecycle records, consumer dependencies, exposure history, rotations, evidence, decisions, exceptions, recovery, and open gaps. Never place secret values in continuity artifacts. Hand off to IAM, Cryptography, Keys, Application, Platform, Operations, Security Operations, and Incident Response.

RELATED CODEX SECTIONS

045-047 Security, Identity, and Privacy Architecture; 200-204 IAM, Authentication, Authorization, Cryptography, and Keys; 206 Security Operations; 214 Incident Response; 231-254 Testing; 386 Technical Debt; 388 Version Management; 391-395 Data Lifecycle.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

Based on the Canonical Section Contract, shared governance, security architecture, and the integration roadmap. Exact secret classes, providers, rotation tolerance, emergency authority, jurisdiction, retention, and acceptance evidence remain unresolved.

206

SECTION 206 - SECURITY OPERATIONS

CODEX/03_SECTIONS/206_SECURITY_OPERATIONS.txt

SHA-256 d2876b9a692e67276f709fe180c75efa279b30a9a861e1dc06f002e58288f7d9

6,833 BYTES / PRESERVED SOURCE IDENTITY

SECTION 206 — Security Operations

STATUS: CONTENT-COMPLETE

PURPOSE

Operate security controls, telemetry, detection, triage, escalation, containment, communication, evidence, and continuous improvement across the declared environments and services.

REQUIRED OUTCOME

A security-operations model with monitored assets, signal sources, coverage, detection logic, ownership, triage, response authority, escalation, privacy, evidence preservation, continuity, recovery, and measurable gaps.

WHY THIS MATTERS

Security controls are only useful when they are observable, staffed, interpreted, and connected to action. A dashboard, alert, scanner, or automated verdict can miss attacks, overwhelm operators, expose private data, or create unsafe containment if coverage and authority are unclear.

APPLICABILITY

Apply when systems, data, identities, devices, applications, networks, providers, or physical assets require ongoing security monitoring, detection, response, assurance, or evidence.

NON-APPLICABILITY CONDITIONS

Record non-applicability only when the scope has no ongoing security signal, protected asset, operational action, or incident consequence and an approved exact baseline documents that conclusion.

PREREQUISITES AND DEPENDENCIES

Use security, identity, privacy, threat, vulnerability, incident, continuity, operations, legal, records, and architecture baselines. Identify assets, telemetry, operators, response authority, service windows, retention, and dependencies.

REQUIRED INPUTS

Asset inventory, threat model, telemetry, logs, detections, baselines, vulnerabilities, identities, providers, response plans, escalation, staffing, privacy limits, retention, incidents, and service objectives.

HUMAN RESPONSIBILITIES AND AUTHORITY

Security owners approve coverage, severity, response, containment, evidence, notification, exceptions, staffing, privacy handling, and risk acceptance. Humans decide material containment, public or customer communication, attribution, legal escalation, and closure.

AI RESPONSIBILITIES AND BOUNDARIES

AI may correlate authorized signals, summarize events, identify anomalies, draft triage and hunt hypotheses, and propose bounded response steps. It must preserve source, time, asset, identity, confidence, and privacy boundaries; distinguish signal from incident and recommendation from action; and expose missing coverage. It must not suppress alerts, attribute an actor, isolate assets, revoke access, delete evidence, or close an incident without delegated authority and human control.

APPLICABLE EXISTING AGENT ROLES

Security Auditor, Observer, Analyst, Researcher, Threat Intelligence Analyst, Incident Responder, Architect, Coordinator, Implementer, Tester, Verifier, Governance Reviewer, Critic, Red Team, Documentation Writer, and Memory Curator.

REQUIRED ACTIVITIES

Define monitored assets and coverage; collect and protect signals; establish baselines and detections; triage and prioritize; investigate and preserve evidence; escalate and communicate; contain and recover under authority; tune controls; measure gaps; test playbooks; and record lessons and reopening conditions.

HUMAN-AI INTERACTION REQUIREMENTS

Show event source, asset, identity, time, correlation, confidence, privacy impact, recommended action, authority, and missing evidence. Require human review for containment, attribution, notification, data access, evidence destruction, and closure. Preserve operator override, pause, appeal, and manual response.

ARCHITECTURE AND SYSTEM IMPLICATIONS

Separate telemetry collection, normalization, detection, case management, evidence, response orchestration, identity, and retention. Design for clock differences, missing logs, provider loss, tampering, data minimization, and safe degraded operation. Keep response authority distinct from mere signal generation.

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show coverage, asset state, active alerts and cases, severity, evidence freshness, operator, response authority, dependencies, privacy constraints, and open gaps. Provide authorized acknowledge, escalate, contain, release, preserve, communicate, pause, and close controls with durable audit.

REQUIRED OUTPUTS AND ARTIFACTS

Security-operations charter; asset and telemetry coverage; detection catalog; triage and escalation model; playbooks; evidence and privacy handling; staffing and service measures; test, incident, exception, decision, and continuity records.

EVIDENCE REQUIREMENTS

Identify asset, source, event, identity, time, clock basis, method, detection version, analyst or agent, result, confidence, coverage, and limitation. An alert, clean scan, or absent event proves only the declared visibility and rule scope.

VERIFICATION AND ACCEPTANCE TESTS

Exercise expected and adversarial signals, missing telemetry, duplicate events, clock skew, false positives, false negatives, provider loss, tampered logs, high volume, privacy filtering, containment, evidence preservation, recovery, and closure.

FAILURE STATES AND ANTI-PATTERNS

Alert fatigue, unowned detections, blind spots, retention too short for investigation, unprotected logs, automatic containment without authority, attribution from weak evidence, and treating absence of alerts as absence of attack.

RECOVERY AND RECONSIDERATION

Preserve available evidence, declare the gap, narrow or isolate affected actions, restore telemetry, and use manual or alternate detection. Reassess scope, privacy, user impact, containment, legal duties, and residual risk before closing. Reopen on asset, provider, threat, telemetry, policy, or staffing change.

COMPLETION CRITERIA

Assets, coverage, signals, detections, owners, authority, triage, evidence, privacy, response, recovery, tests, measures, gaps, and reopening conditions are explicit. Status remains CONTENT-COMPLETE pending independent verification and owner acceptance.

HANDOFF AND CONTINUITY REQUIREMENTS

Preserve coverage baselines, detections, case state, evidence references, decisions, communications, incidents, exceptions, staffing assumptions, and open gaps. Hand off to Threat Intelligence, Threat Modeling, Vulnerability, Incident Response, Operations, Privacy, Records, Testing, and Governance.

RELATED CODEX SECTIONS

045-047 Security, Identity, and Privacy Architecture; 200-205 Identity, Authentication, Authorization, Cryptography, Keys, and Secrets; 207-218 Threat, Vulnerability, Incident, Fraud, Abuse, Trust, and Privacy; 301-330 Operations and Recovery; 402-406 Review and Retirement.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

Based on the Canonical Section Contract, shared governance, security architecture, and the integration roadmap. Exact telemetry, staffing, response authority, retention, notification, privacy, jurisdiction, and service objectives remain unresolved.

207

SECTION 207 - THREAT INTELLIGENCE

CODEX/03_SECTIONS/207_THREAT_INTELLIGENCE.txt

SHA-256 52158f0df7a53e1ff5476f28a9eb1e2eab1e43858512ed3183caf70c00e87176

6,626 BYTES / PRESERVED SOURCE IDENTITY

SECTION 207 — Threat Intelligence

STATUS: CONTENT-COMPLETE

PURPOSE

Collect, evaluate, contextualize, protect, and communicate information about threats, actors, techniques, campaigns, exposures, and defensive implications relevant to the declared system and decision scope.

REQUIRED OUTCOME

A threat-intelligence process with source governance, collection requirements, confidence and provenance, relevance, analysis, dissemination, privacy, handling, action mapping, feedback, and explicit uncertainty.

WHY THIS MATTERS

Threat information can be stale, manipulated, duplicated, overgeneralized, or irrelevant to the target environment. Treating an indicator, headline, vendor claim, or model-generated narrative as verified intelligence can cause wasted effort, unsafe blocking, or false attribution.

APPLICABILITY

Apply when security decisions depend on external or internal information about threats, adversaries, techniques, vulnerabilities, campaigns, abuse, fraud, geopolitical or sector conditions, or emerging risk.

NON-APPLICABILITY CONDITIONS

Record non-applicability only when no threat-informed decision, protected asset, intelligence source, or risk change is in scope and an approved exact baseline supports it.

PREREQUISITES AND DEPENDENCIES

Use security operations, threat modeling, vulnerability, privacy, legal, source-handling, incident, and governance baselines. Define consumers, decisions, source authority, handling restrictions, classification, and action owners.

REQUIRED INPUTS

Intelligence requirements, assets, sectors, threats, source inventory, indicators, reports, telemetry, vulnerabilities, incidents, confidence model, handling rules, consumers, decision thresholds, and unresolved questions.

HUMAN RESPONSIBILITIES AND AUTHORITY

Owners define intelligence requirements, source acceptance, handling, confidence, dissemination, collection limits, attribution posture, action thresholds, and risk acceptance. Humans approve sensitive collection, sharing, attribution, blocking, notification, and use in consequential decisions.

AI RESPONSIBILITIES AND BOUNDARIES

AI may retrieve authorized sources, normalize indicators, compare reports, identify contradictions, draft analytic questions, and map intelligence to declared assets and controls. It must preserve provenance, freshness, handling, confidence, source limitation, and uncertainty. It must not fabricate sources, expose restricted intelligence, infer attribution, or trigger blocking or response without delegated authority and human review.

APPLICABLE EXISTING AGENT ROLES

Threat Intelligence Analyst, Researcher, Analyst, Security Auditor, Observer, Architect, Security Operations Analyst, Verifier, Critic, Red Team, Governance Reviewer, Documentation Writer, and Memory Curator.

REQUIRED ACTIVITIES

Define intelligence requirements; inventory and qualify sources; collect within authority; preserve provenance; normalize and correlate; assess relevance, confidence, and contradiction; produce decision-ready analysis; disseminate by need and handling; map to controls; solicit feedback; expire stale intelligence; record decisions.

HUMAN-AI INTERACTION REQUIREMENTS

Show source, date, collection method, handling, confidence, corroboration, contradiction, target relevance, and recommended use. Require human review for attribution, sensitive dissemination, blocking, incident declaration, or high-impact risk decisions. Keep intelligence separate from fact, assumption, and action.

ARCHITECTURE AND SYSTEM IMPLICATIONS

Separate collection, source identity, storage, analysis, classification, dissemination, indicator use, audit, retention, and destruction. Bind indicators to context and expiry, prevent untrusted input from becoming executable control, and protect sources and affected people.

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show intelligence requirement, source, freshness, confidence, relevance, handling, affected assets, contradictions, action state, owner, and evidence. Provide authorized accept, reject, expire, restrict, share, investigate, and reopen controls with rationale.

REQUIRED OUTPUTS AND ARTIFACTS

Intelligence requirements; source and handling register; collection and confidence model; analytic products; indicator and context catalog; action mapping; contradiction, decision, evidence, exception, and continuity records.

EVIDENCE REQUIREMENTS

Identify source, publisher or origin, collection time, version, handling, method, corroboration, target, analyst, confidence, result, and limitation. A feed hit or generated summary proves only the source claim and declared context.

VERIFICATION AND ACCEPTANCE TESTS

Verify source identity, freshness, provenance, handling, indicator context, expiry, contradiction, relevance, dissemination, access, and action mapping. Test poisoned or unavailable sources, conflicting reports, stale indicators, false positives, and unauthorized sharing.

FAILURE STATES AND ANTI-PATTERNS

Source laundering, false attribution, indicator without context, stale feed treated as current, vendor or model narrative treated as fact, uncontrolled collection, indiscriminate sharing, and intelligence used to bypass due process.

RECOVERY AND RECONSIDERATION

Quarantine questionable products or indicators, retract or annotate dissemination, preserve provenance, notify consumers, and reassess actions based on corrected or corroborated evidence. Reopen on source compromise, threat change, target change, or material contradiction.

COMPLETION CRITERIA

Requirements, sources, handling, provenance, confidence, relevance, outputs, consumers, actions, evidence, uncertainty, and reopening conditions are explicit. Status remains CONTENT-COMPLETE pending independent verification and owner acceptance.

HANDOFF AND CONTINUITY REQUIREMENTS

Preserve source and product identity, handling, decisions, indicators, expiry, contradictions, evidence, dissemination, incidents, and open gaps. Hand off to Threat Modeling, Security Operations, Vulnerability, Incident Response, Privacy, Legal, and Governance.

RELATED CODEX SECTIONS

018 Risk Management; 045 Security Architecture; 206 Security Operations; 208 Threat Modeling; 209 Vulnerability Management; 210-212 Testing and Teaming; 214 Incident Response; 217 Trust and Safety.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

Based on the Canonical Section Contract, shared governance, security operations context, and the integration roadmap. Exact source authorities, sharing agreements, confidence model, privacy limits, attribution policy, retention, and owner acceptance remain unresolved.

208

SECTION 208 - THREAT MODELING

CODEX/03_SECTIONS/208_THREAT_MODELING.txt

SHA-256 54fce8242c72755d9f609dd400bc8c96fb0ce00089e6dcf99911f35bf01b36ae

6,687 BYTES / PRESERVED SOURCE IDENTITY

SECTION 208 — Threat Modeling

STATUS: CONTENT-COMPLETE

PURPOSE

Make security, safety, privacy, abuse, fraud, and resilience threats explicit early enough to shape requirements, architecture, controls, tests, operations, and owner decisions.

REQUIRED OUTCOME

A versioned threat model with assets, actors, trust boundaries, entry points, assumptions, threats, abuse cases, impacts, likelihood or uncertainty, mitigations, residual risk, owners, evidence, and reopening conditions.

WHY THIS MATTERS

Threats that remain implicit are rarely tested or owned. A model can also create false assurance when it lists generic threats without the actual system, adversary capability, affected people, control limits, or evidence that mitigations work.

APPLICABILITY

Apply when a system, product, process, device, data set, organization, AI capability, or change can create security, safety, privacy, financial, social, operational, or abuse consequences.

NON-APPLICABILITY CONDITIONS

Record non-applicability only for a bounded, low-consequence, reversible scope with no material trust boundary, protected asset, affected party, or new threat assumption, supported by an approved exact baseline.

PREREQUISITES AND DEPENDENCIES

Use current requirements, architecture, data and process models, user and owner context, incidents, intelligence, vulnerabilities, privacy, safety, legal, and operational evidence. Identify model owner, affected parties, review authority, and change triggers.

REQUIRED INPUTS

Objective, scope, assets, people, actors, identities, data, flows, interfaces, environments, trust boundaries, assumptions, dependencies, threats, impacts, controls, incidents, evidence, and unresolved questions.

HUMAN RESPONSIBILITIES AND AUTHORITY

Owners identify unacceptable harm, protected populations, risk appetite, legal or safety duties, authority boundaries, and acceptance criteria. Humans approve threat scope, residual risk, exceptions, high-impact mitigations, and decisions affecting rights, access, safety, or public communication.

AI RESPONSIBILITIES AND BOUNDARIES

AI may inspect authorized architecture and evidence, enumerate threat hypotheses, compare patterns, draft abuse cases and tests, identify missing assumptions, and challenge the model. It must distinguish source, observation, inference, scenario, likelihood, impact, and recommendation. It must not claim exhaustive coverage, invent actors or evidence, set risk acceptance, or authorize defensive or offensive action without delegation.

APPLICABLE EXISTING AGENT ROLES

Architect, Security Auditor, Risk Analyst, Researcher, Observer, Analyst, Critic, Red Team, Safety Reviewer, Privacy Reviewer, Tester, Verifier, Governance Reviewer, Documentation Writer, and Memory Curator.

REQUIRED ACTIVITIES

Define purpose and scope; inventory assets and affected parties; map flows and trust boundaries; identify actors and capabilities; enumerate threats and abuse cases; assess impact and uncertainty; map controls and owners; identify residual risk; design tests; review dissent; baseline and reopen on change.

HUMAN-AI INTERACTION REQUIREMENTS

Show model version, scope, assumptions, evidence, actor capability, affected party, impact, uncertainty, mitigation owner, and residual risk. Require human review for high-impact scenarios, acceptance, exceptions, and changes to protected outcomes. Preserve disagreement and unknowns rather than converting them into confidence.

ARCHITECTURE AND SYSTEM IMPLICATIONS

Represent assets, flows, trust boundaries, identities, controls, events, assumptions, and threats as traceable versioned records. Link each material threat to preventive, detective, responsive, and recovery controls, tests, evidence, and an owner. Model human, AI, supplier, physical, and organizational boundaries where relevant.

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show scope, model version, assets, threats, impacts, assumptions, confidence, control coverage, residual risk, owners, open dissent, and change triggers. Provide authorized accept, reject, defer, assign, reopen, and risk-escalation controls with rationale and evidence.

REQUIRED OUTPUTS AND ARTIFACTS

Threat-model charter; asset and actor inventory; data-flow and trust-boundary model; threat and abuse-case register; control and test mapping; residual-risk and exception register; review, decision, evidence, and continuity records.

EVIDENCE REQUIREMENTS

Identify system version, scope, asset, actor, assumption, source, method, scenario, impact, uncertainty, control, test, owner, and limitation. A checklist or generic threat library proves neither coverage nor mitigation effectiveness.

VERIFICATION AND ACCEPTANCE TESTS

Independently reconstruct the model; challenge assumptions; verify assets, actors, boundaries, threats, mitigations, owners, and tests; exercise high-impact scenarios; compare with incidents and intelligence; and confirm change triggers and residual-risk decisions.

FAILURE STATES AND ANTI-PATTERNS

Generic checklist theater, missing affected people, trust boundary omission, threat count as quality, risk score without evidence, mitigation without owner, silent dissent, and model treated as complete after architecture changes.

RECOVERY AND RECONSIDERATION

Mark affected conclusions stale, preserve prior model and evidence, narrow the decision, and obtain the missing architecture, source, or human judgment. Reassess controls and residual risk after incidents, changes, new intelligence, population shifts, or newly discovered harms.

COMPLETION CRITERIA

Scope, assets, actors, boundaries, threats, impacts, controls, tests, owners, evidence, residual risk, dissent, and reopening conditions are explicit. Status remains CONTENT-COMPLETE pending independent review and owner acceptance.

HANDOFF AND CONTINUITY REQUIREMENTS

Preserve model identity, assumptions, decisions, evidence, threat history, control mapping, tests, exceptions, dissent, and open gaps. Hand off to Architecture, Requirements, Security Operations, Vulnerability, Red Team, Blue Team, Privacy, Safety, Testing, and Governance.

RELATED CODEX SECTIONS

018 Risk Management; 019 Requirements Engineering; 020-047 Architecture; 206 Security Operations; 207 Threat Intelligence; 209 Vulnerability Management; 210-212 Teaming and Testing; 214 Incident Response; 217 Trust and Safety.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

Based on the Canonical Section Contract, shared governance, requirements and architecture context, and the integration roadmap. Exact threat sources, risk method, adversary capability, affected populations, sector obligations, and acceptance authority remain unresolved.

209

SECTION 209 - VULNERABILITY MANAGEMENT

CODEX/03_SECTIONS/209_VULNERABILITY_MANAGEMENT.txt

SHA-256 70dc340fa0a9277ff606c0f2bd71103186c3de0618eeefc60a2108537ac750d2

6,529 BYTES / PRESERVED SOURCE IDENTITY

SECTION 209 — Vulnerability Management

STATUS: CONTENT-COMPLETE

PURPOSE

Discover, validate, prioritize, remediate, mitigate, disclose, and verify weaknesses across the declared assets, dependencies, configurations, code, hardware, data, and suppliers.

REQUIRED OUTCOME

A vulnerability lifecycle with asset coverage, source and finding provenance, severity and exploitability context, owner, deadline, remediation or mitigation, exception, verification, disclosure, evidence, and reopening rules.

WHY THIS MATTERS

A scanner finding may be false, stale, duplicated, unexploitable, or more serious than its score suggests. Untracked assets, unsupported versions, accepted exceptions, and unverified fixes leave the real exposure unknown.

APPLICABILITY

Apply when a system, product, device, dependency, provider, configuration, process, or supplier can contain a weakness that affects security, privacy, safety, availability, or trust.

NON-APPLICABILITY CONDITIONS

Record non-applicability only when no asset, dependency, configuration, weakness, security property, or disclosure obligation is affected and an approved exact baseline documents the conclusion.

PREREQUISITES AND DEPENDENCIES

Use asset inventory, threat intelligence, threat model, security operations, change, testing, supplier, patching, incident, legal, and risk baselines. Define owners, environments, exposure, supported versions, severity method, and remediation authority.

REQUIRED INPUTS

Asset and dependency inventory, versions, configurations, scan and test results, advisories, exploit context, exposure, business and safety impact, owners, deadlines, mitigations, exceptions, disclosure, and verification evidence.

HUMAN RESPONSIBILITIES AND AUTHORITY

Owners validate findings, assign priority and remediation, approve mitigations and exceptions, decide disclosure and service interruption, and accept residual risk. Humans resolve disputed severity, safety or privacy impact, supplier communication, and overdue escalation.

AI RESPONSIBILITIES AND BOUNDARIES

AI may normalize authorized findings, deduplicate, compare affected versions, enrich with approved intelligence, draft remediation and test plans, and identify missing asset coverage. It must preserve source, asset, version, evidence, confidence, and impact boundaries. It must not exploit systems, close findings, set severity, approve exceptions, or claim remediation without authorization and human verification.

APPLICABLE EXISTING AGENT ROLES

Security Auditor, Vulnerability Analyst, Researcher, Threat Intelligence Analyst, Architect, Implementer, Tester, Verifier, Governance Reviewer, Critic, Coordinator, Documentation Writer, and Memory Curator.

REQUIRED ACTIVITIES

Maintain asset coverage; collect and qualify findings; validate scope and exploitability; prioritize impact and exposure; assign owners and deadlines; remediate or mitigate; coordinate disclosure; retest; manage exceptions; monitor drift; report overdue risk; and retire stale findings with evidence.

HUMAN-AI INTERACTION REQUIREMENTS

Show asset, version, source, finding, exposure, evidence, severity rationale, owner, deadline, recommendation, and limitation. Require human approval for testing scope, production changes, exception, disclosure, service interruption, and closure. Do not expose sensitive findings beyond need to know.

ARCHITECTURE AND SYSTEM IMPLICATIONS

Connect inventory, dependency, finding, risk, change, patch, test, incident, supplier, and evidence records. Preserve affected-version and configuration context; support compensating controls, safe rollout, rollback, and verified closure. Make unsupported or unknown assets visible.

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show coverage, open findings, exposure, severity rationale, owner, deadline, evidence freshness, mitigation, exception, disclosure, dependencies, and authorized assign, prioritize, remediate, defer, accept, reopen, and close controls.

REQUIRED OUTPUTS AND ARTIFACTS

Asset and coverage baseline; finding register; severity and prioritization method; remediation and mitigation plans; exception and disclosure records; retest results; decision, evidence, incident, and continuity records.

EVIDENCE REQUIREMENTS

Identify asset, version, configuration, source, finding, method, time, exposure, impact, confidence, owner, result, and limitation. A scanner result or clean scan proves only its engine, configuration, timing, and coverage.

VERIFICATION AND ACCEPTANCE TESTS

Verify inventory completeness, finding identity, affected version, exposure, severity rationale, remediation, mitigation, rollback, retest, exception expiry, disclosure, and closure. Test stale scan data, false positives, duplicate findings, unsupported assets, and provider outage.

FAILURE STATES AND ANTI-PATTERNS

Scanner theater, severity by score alone, unowned findings, indefinite exceptions, closing after patch deployment without retest, ignoring unsupported assets, and testing production without authority or safety controls.

RECOVERY AND RECONSIDERATION

Preserve findings and evidence, narrow exposure, apply approved mitigation or rollback, notify owners, and reopen invalid closures. Reassess user, safety, privacy, and service impact after new intelligence, configuration change, exploit, incident, or supplier notice.

COMPLETION CRITERIA

Assets, coverage, findings, owners, priority, remediation, mitigation, exceptions, disclosure, verification, evidence, deadlines, and reopening conditions are explicit. Status remains CONTENT-COMPLETE pending independent verification and owner acceptance.

HANDOFF AND CONTINUITY REQUIREMENTS

Preserve finding identifiers, affected versions, decisions, exceptions, evidence, remediation state, disclosure, incidents, and open gaps. Hand off to Security Operations, Threat Intelligence, Threat Modeling, Testing, Release, Maintenance, Suppliers, and Governance.

RELATED CODEX SECTIONS

018 Risk Management; 045 Security Architecture; 198-206 Embedded, Hardware, IAM, Cryptography, Keys, Secrets, and Security Operations; 207 Threat Intelligence; 208 Threat Modeling; 231-254 Testing; 378-381 Updates and Patching; 386-389 Technical Debt and Versioning.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

Based on the Canonical Section Contract, shared governance, security operations context, and the integration roadmap. Exact asset coverage, scoring, deadlines, disclosure duties, supplier support, exception authority, and acceptance evidence remain unresolved.

210

SECTION 210 - PENETRATION TESTING

CODEX/03_SECTIONS/210_PENETRATION_TESTING.txt

SHA-256 568aa0c3ed76d8e53f0ea97573bb126f1755a1be76c087e72785e3723cd2a226

6,516 BYTES / PRESERVED SOURCE IDENTITY

SECTION 210 — Penetration Testing

STATUS: CONTENT-COMPLETE

PURPOSE

Perform authorized, bounded security testing that validates whether real systems, controls, configurations, interfaces, and recovery paths resist declared attack scenarios.

REQUIRED OUTCOME

A scoped penetration-test plan and evidence package with authorization, targets, exclusions, safety limits, methods, observations, findings, impact, reproducibility, remediation, retest, and owner acceptance.

WHY THIS MATTERS

A penetration test can reveal control interaction and real exposure that reviews or scanners miss, but an unsafe or poorly scoped test can cause outage, data exposure, legal conflict, or false confidence. A clean result is bounded by scope, time, method, and tester access.

APPLICABILITY

Apply when authorized adversarial testing can materially validate security of applications, networks, devices, APIs, identities, cloud resources, facilities, or operational controls.

NON-APPLICABILITY CONDITIONS

Record non-applicability when testing would add no material information beyond current verified evidence, the scope is non-consequential and reversible, or authorization and safe test conditions cannot be established. The determination must name the alternative evidence and reopening condition.

PREREQUISITES AND DEPENDENCIES

Obtain written authorization, target and exclusion list, rules of engagement, contacts, safety and privacy controls, data handling, legal review where needed, rollback and stop conditions, environment access, and incident or support coverage.

REQUIRED INPUTS

Objective, scope, assets, versions, environments, identities, test accounts, allowed methods, exclusions, schedule, rate limits, data constraints, safety limits, threat model, prior findings, evidence, and acceptance criteria.

HUMAN RESPONSIBILITIES AND AUTHORITY

Owners authorize scope, methods, timing, data access, stop conditions, risk, and communication. Test leads protect evidence and people. Humans decide whether testing may affect production, whether a finding requires immediate containment, and whether residual risk is accepted.

AI RESPONSIBILITIES AND BOUNDARIES

AI may help draft scope, test cases, evidence plans, code or configuration review, and bounded analysis of authorized results. It must preserve authorization and target boundaries, avoid secret exposure, and distinguish observed behavior from inference. It must not initiate testing, expand scope, exploit, persist, exfiltrate, alter, or publish findings without explicit authorized execution and human oversight.

APPLICABLE EXISTING AGENT ROLES

Security Auditor, Penetration Tester, Architect, Researcher, Analyst, Implementer, Observer, Tester, Verifier, Governance Reviewer, Critic, Red Team, Documentation Writer, and Memory Curator.

REQUIRED ACTIVITIES

Define objective and rules; verify authorization; inventory and validate targets; prepare safety and stop controls; execute bounded tests; record evidence; triage findings; notify urgent risk; clean up; remediate; retest; report limitations; preserve continuity.

HUMAN-AI INTERACTION REQUIREMENTS

Display authorization, target, method, account, environment, time, rate, evidence, and stop state before consequential activity. Require human approval for scope, production testing, data access, exploit execution, containment, and disclosure. Provide immediate stop and escalation paths.

ARCHITECTURE AND SYSTEM IMPLICATIONS

Separate test identity, test control, target, telemetry, evidence, notification, rollback, and production authority. Ensure tests are attributable, rate-limited, reversible where possible, isolated from real data, and visible to defenders without invalidating the declared exercise.

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show authorization, scope, active test, targets, methods, safety state, findings, evidence, contacts, and impact. Provide authorized start, pause, stop, narrow, escalate, clean up, approve remediation, retest, and close controls.

REQUIRED OUTPUTS AND ARTIFACTS

Authorization and rules of engagement; target and exclusion register; test plan; evidence and data-handling plan; findings and severity rationale; cleanup, remediation, retest, exception, decision, evidence, and continuity records.

EVIDENCE REQUIREMENTS

Identify authorization, tester or agent, target, version, environment, method, timestamp, account, observed result, evidence location, impact, reproduction boundary, and limitation. Do not retain unnecessary sensitive data or weaponized material.

VERIFICATION AND ACCEPTANCE TESTS

Verify authorization and scope before start; exercise stop, rate, privacy, cleanup, and evidence controls; reproduce material findings safely; validate remediation and retest; confirm no unauthorized target or data was affected; and obtain owner acceptance of limitations.

FAILURE STATES AND ANTI-PATTERNS

Testing without authorization, scope drift, production impact without approval, uncontrolled exploit or data collection, unannounced testing that defeats safety, clean result treated as total security, and findings published without handling controls.

RECOVERY AND RECONSIDERATION

Stop immediately on unsafe, out-of-scope, or unexpected impact; preserve state and evidence; notify the owner and incident path; clean up or restore under authority; assess data and user impact; and reopen findings or scope when evidence changes.

COMPLETION CRITERIA

Authorization, scope, methods, safety, findings, evidence, limitations, remediation, retest, owner decisions, and reopening conditions are explicit. Status remains CONTENT-COMPLETE pending independent review and owner acceptance.

HANDOFF AND CONTINUITY REQUIREMENTS

Preserve rules, target identity, test timeline, findings, evidence references, cleanup, remediation, retest, exceptions, and open gaps. Hand off to Security Operations, Vulnerability, Threat Modeling, Red Team, Blue Team, Incident Response, Testing, and Governance.

RELATED CODEX SECTIONS

018 Risk Management; 045 Security Architecture; 206 Security Operations; 208 Threat Modeling; 209 Vulnerability Management; 211 Red Teaming; 212 Blue Teaming; 231-254 Testing; 402-404 Review and Postmortem.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

Based on the Canonical Section Contract, shared governance, security architecture, and the integration roadmap. Exact testing standards, authorization authority, production tolerance, data handling, legal constraints, and acceptance evidence remain unresolved.

211

SECTION 211 - RED TEAMING

CODEX/03_SECTIONS/211_RED_TEAMING.txt

SHA-256 6766840e6e0af8cb22a7a503b32ae1eae65d33764c2327f6be1c706453a3db91

6,781 BYTES / PRESERVED SOURCE IDENTITY

SECTION 211 — Red Teaming

STATUS: CONTENT-COMPLETE

PURPOSE

Conduct authorized, adversary-oriented exercises that test whether people, processes, technology, facilities, and governance detect, resist, contain, communicate, and recover from realistic attack paths.

REQUIRED OUTCOME

A governed red-team exercise with objective, threat scenario, authorization, scope, safety boundaries, independent control, rules, evidence, defender interaction, findings, impact, remediation, lessons, and owner decisions.

WHY THIS MATTERS

Security controls can pass isolated tests while failing as a system. Red teaming exposes assumptions and interactions, but it can also harm people or operations if secrecy, safety, privacy, legal authority, and stop conditions are weak. Exercise success is not proof of total resilience.

APPLICABILITY

Apply when an authorized adversary-emulation exercise can reveal material weaknesses in prevention, detection, response, decision-making, physical security, social process, or recovery.

NON-APPLICABILITY CONDITIONS

Record non-applicability when the consequence, scope, or authority cannot support a safe exercise and a lower-risk test provides the required evidence, or when no material adversarial path is in scope. Record the alternative and reopening condition.

PREREQUISITES AND DEPENDENCIES

Require executive or accountable-owner authorization, objective and success criteria, independent exercise control, target and exclusion list, rules of engagement, legal and privacy review, safety contacts, emergency stop, data handling, and defender coordination appropriate to the scenario.

REQUIRED INPUTS

Threat model, intelligence, assets, people, environments, objectives, scenarios, constraints, access, test identities, communications, safety limits, evidence plan, response capability, and acceptance criteria.

HUMAN RESPONSIBILITIES AND AUTHORITY

Owners authorize objectives, scope, acceptable risk, secrecy, safety, communication, and stop conditions. Exercise control can halt activity. Humans decide whether physical, social, production, or high-impact actions are allowed and how affected people are protected.

AI RESPONSIBILITIES AND BOUNDARIES

AI may help analyze threats, draft scenarios, review authorized exercise evidence, identify control gaps, and propose safe tests. It must preserve authorization, target, identity, time, and handling boundaries. It must not autonomously conduct intrusion, deception, social engineering, persistence, exfiltration, destructive action, or scope expansion without explicit authorization and human supervision.

APPLICABLE EXISTING AGENT ROLES

Red Team Lead, Security Auditor, Threat Intelligence Analyst, Threat Modeler, Researcher, Architect, Observer, Tester, Verifier, Governance Reviewer, Critic, Coordinator, Documentation Writer, and Memory Curator.

REQUIRED ACTIVITIES

Define objective and scenario; obtain authority; establish control and safety; map targets and exclusions; prepare communications and stop paths; execute bounded emulation; record observations; protect participants and evidence; deconflict; analyze detection and response; remediate; retest; conduct post-exercise review.

HUMAN-AI INTERACTION REQUIREMENTS

Show exercise authority, scenario, target, method, safety state, identity, evidence, and stop control. Require human approval for every escalation into physical, social, production, sensitive-data, or external-party activity. Maintain a reachable controller and immediate stop mechanism.

ARCHITECTURE AND SYSTEM IMPLICATIONS

Separate exercise control, test identity, target, telemetry, evidence, communication, real incident response, and production authority. Preserve enough defender visibility to evaluate detection and enough safety isolation to prevent uncontrolled harm. Define how exercise artifacts expire and are destroyed.

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show authorization, objective, scope, active phase, safety state, contacts, evidence, discoveries, impact, and defender status. Provide authorized pause, stop, narrow, deconflict, escalate, disclose, remediate, and close controls with an immutable timeline.

REQUIRED OUTPUTS AND ARTIFACTS

Exercise charter; authorization and rules; threat scenario; target and exclusion register; safety and communication plan; observation and evidence record; findings; remediation and retest; participant impact; decision, postmortem, and continuity records.

EVIDENCE REQUIREMENTS

Identify authority, scenario, target, actor, method, time, environment, observation, source, impact, confidence, and limitation. Protect sensitive exercise details and personal information; do not retain operationally dangerous material beyond the approved need.

VERIFICATION AND ACCEPTANCE TESTS

Verify authorization, scope, emergency stop, participant protection, evidence integrity, deconfliction, detection, response, communication, cleanup, remediation, retest, and owner acceptance. Confirm that exercise results are distinguished from real incidents.

FAILURE STATES AND ANTI-PATTERNS

Unapproved or indefinite exercise, unclear controller, unsafe secrecy, scope drift, harmful deception, uncontrolled persistence, real data exposure, confusing exercise with incident, and celebrating access without measuring detection or recovery.

RECOVERY AND RECONSIDERATION

Stop and declare an incident path on unexpected impact, exposure, or scope conflict. Preserve evidence, notify the controller and owner, clean up or restore, protect affected people, assess legal and operational consequences, and revise the model and rules before resuming.

COMPLETION CRITERIA

Authority, objective, scenario, scope, safety, evidence, findings, defender behavior, remediation, retest, lessons, limitations, and reopening conditions are explicit. Status remains CONTENT-COMPLETE pending independent review and owner acceptance.

HANDOFF AND CONTINUITY REQUIREMENTS

Preserve exercise identity, rules, timeline, findings, evidence references, impact, decisions, remediation, and open gaps with appropriate handling. Hand off to Security Operations, Blue Team, Threat Modeling, Vulnerability, Incident Response, Governance, Testing, and Owners.

RELATED CODEX SECTIONS

018 Risk Management; 206 Security Operations; 207 Threat Intelligence; 208 Threat Modeling; 209 Vulnerability Management; 210 Penetration Testing; 212 Blue Teaming; 214 Incident Response; 402-404 Review and Postmortem.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

Based on the Canonical Section Contract, shared governance, security operations context, and the integration roadmap. Exact exercise authority, target environments, safety limits, legal and privacy obligations, participant protection, and acceptance evidence remain unresolved.

212

SECTION 212 - BLUE TEAMING

CODEX/03_SECTIONS/212_BLUE_TEAMING.txt

SHA-256 52c53edc0ed8f6c502316ddd78369dc5b5a1d5362660925bae7579adaa3251b6

6,708 BYTES / PRESERVED SOURCE IDENTITY

SECTION 212 — Blue Teaming

STATUS: CONTENT-COMPLETE

PURPOSE

Build and continuously improve defensive capability to prevent, detect, investigate, contain, communicate, recover from, and learn from security threats.

REQUIRED OUTCOME

A defensive operating model with asset and telemetry coverage, baselines, detections, analyst workflows, response playbooks, hardening, threat-informed validation, evidence, authority, recovery, and measurable improvement.

WHY THIS MATTERS

Defenders work with incomplete signals, changing systems, limited time, and competing service obligations. A tool deployment or alert rule is not a defensive capability unless people can interpret it, act safely, preserve evidence, and recover.

APPLICABILITY

Apply when a team or capability is responsible for security monitoring, detection, investigation, hardening, response, resilience, or defensive learning for systems, people, data, devices, or facilities.

NON-APPLICABILITY CONDITIONS

Record non-applicability only when no ongoing defensive activity, protected asset, security signal, response authority, or material threat is in scope and an approved exact baseline supports it.

PREREQUISITES AND DEPENDENCIES

Use security operations, threat intelligence, threat modeling, vulnerability, incident, identity, privacy, continuity, records, staffing, and architecture baselines. Identify assets, coverage, defenders, escalation, authority, tools, training, and recovery objectives.

REQUIRED INPUTS

Asset inventory, threats, intelligence, telemetry, detections, baselines, vulnerabilities, incidents, playbooks, staffing, skills, privacy limits, evidence requirements, service objectives, and owner decisions.

HUMAN RESPONSIBILITIES AND AUTHORITY

Defensive owners approve monitoring, hardening, detection, containment, evidence, user communication, staffing, exceptions, and residual risk. Humans decide high-impact response, attribution, notification, service interruption, and closure; defenders must be able to stop unsafe automation.

AI RESPONSIBILITIES AND BOUNDARIES

AI may summarize authorized signals, correlate events, draft detection logic and playbooks, propose hunts or hardening, and identify coverage gaps. It must preserve asset, source, time, confidence, privacy, and authority boundaries. It must not alter production defenses, block users, delete evidence, attribute incidents, or close cases without explicit delegation and human oversight.

APPLICABLE EXISTING AGENT ROLES

Security Operations Analyst, Blue Team Lead, Security Auditor, Threat Intelligence Analyst, Threat Modeler, Observer, Analyst, Implementer, Tester, Verifier, Governance Reviewer, Critic, Coordinator, Documentation Writer, and Memory Curator.

REQUIRED ACTIVITIES

Define defensive objectives and assets; measure coverage; establish baselines and detections; triage and investigate; harden and patch; exercise playbooks; coordinate red-team and incident work; preserve evidence; contain and recover; tune controls; train operators; measure outcomes; record lessons.

HUMAN-AI INTERACTION REQUIREMENTS

Show source, asset, event, context, confidence, recommended action, authority, and expected impact. Require human approval for detection deployment, hardening, containment, account or device action, evidence handling, notification, and closure. Maintain manual fallback and accessible operator controls.

ARCHITECTURE AND SYSTEM IMPLICATIONS

Separate collection, detection, analysis, case, response, hardening, identity, evidence, and recovery. Design for missing telemetry, adversarial input, provider loss, false positives, alert volume, privacy, and safe degradation. Ensure defensive changes are versioned, tested, reversible, and attributable.

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show defensive coverage, asset posture, active cases, detections, findings, evidence freshness, operator, authority, dependencies, and unresolved gaps. Provide authorized tune, pause, deploy, rollback, contain, release, preserve, escalate, and close controls with rationale and audit.

REQUIRED OUTPUTS AND ARTIFACTS

Defensive charter; coverage and telemetry baseline; detection catalog; hardening and response playbooks; training and staffing model; exercise results; case, incident, remediation, decision, evidence, and continuity records.

EVIDENCE REQUIREMENTS

Identify asset, signal, source, time, clock basis, detection or playbook version, analyst or agent, method, action, result, confidence, coverage, and limitation. A clean dashboard or absence of alert proves only the observed coverage.

VERIFICATION AND ACCEPTANCE TESTS

Exercise expected and adversarial signals, missing logs, false positives, false negatives, provider loss, tampered evidence, alert overload, hardening rollback, containment, recovery, communication, and operator handoff. Reproduce material defensive claims independently.

FAILURE STATES AND ANTI-PATTERNS

Tool-first defense, alert fatigue, unowned playbooks, automatic blocking without authority, lost evidence, hardening that breaks service, detection blind spots, and metrics optimized for activity rather than protected outcomes.

RECOVERY AND RECONSIDERATION

Preserve evidence, narrow unsafe actions, restore or substitute telemetry, revert harmful hardening, escalate, and use manual response. Reassess user impact, service continuity, privacy, and residual risk before resuming. Reopen on threat, asset, provider, staffing, architecture, or telemetry change.

COMPLETION CRITERIA

Assets, coverage, threats, detections, playbooks, owners, authority, evidence, response, recovery, tests, measures, limitations, and reopening conditions are explicit. Status remains CONTENT-COMPLETE pending independent verification and owner acceptance.

HANDOFF AND CONTINUITY REQUIREMENTS

Preserve defensive baseline, detections, playbooks, case state, exercises, evidence, decisions, incidents, exceptions, staffing assumptions, and open gaps. Hand off to Security Operations, Threat Intelligence, Threat Modeling, Vulnerability, Red Team, Incident Response, Operations, Testing, and Governance.

RELATED CODEX SECTIONS

045 Security Architecture; 206 Security Operations; 207 Threat Intelligence; 208 Threat Modeling; 209 Vulnerability Management; 210 Penetration Testing; 211 Red Teaming; 214 Incident Response; 301-330 Operations and Recovery; 402-404 Review and Postmortem.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

Based on the Canonical Section Contract, shared governance, security operations context, and the integration roadmap. Exact defensive staffing, telemetry, response authority, service objectives, privacy, retention, training, and acceptance evidence remain unresolved.

213

SECTION 213 - DIGITAL FORENSICS

CODEX/03_SECTIONS/213_DIGITAL_FORENSICS.txt

SHA-256 f586f07357bcc51c4a4a5ad4d318cb718fd1d5ca5786cf5e0a2e7363b9a4759d

6,264 BYTES / PRESERVED SOURCE IDENTITY

SECTION 213 — Digital Forensics

STATUS: CONTENT-COMPLETE

PURPOSE

Preserve, acquire, examine, analyze, and report digital evidence in a lawful, controlled, reproducible, and privacy-aware manner.

REQUIRED OUTCOME

A forensic plan and evidence package with authority, scope, preservation, acquisition, integrity, chain of custody, analysis, reporting, access control, retention, disclosure, and limitation records.

WHY THIS MATTERS

Digital evidence is volatile, duplicable, privacy-sensitive, and easy to alter. A technically plausible finding is not reliable if the source, acquisition method, time, integrity, analyst, or chain of custody cannot be reconstructed.

APPLICABILITY

Apply when system, device, cloud, application, network, identity, log, communication, or data artifacts may support incident response, legal action, safety review, fraud investigation, compliance, or learning.

NON-APPLICABILITY CONDITIONS

Record non-applicability when no evidentiary question, preservation duty, incident, dispute, or consequential decision requires forensic handling and an approved exact baseline documents why ordinary operational records are sufficient.

PREREQUISITES AND DEPENDENCIES

Obtain authority, scope, legal and privacy guidance, preservation direction, evidence storage, trained personnel, time source, tooling, access, safety controls, and incident or records coordination.

REQUIRED INPUTS

Question, scope, systems, devices, accounts, time window, legal authority, preservation notice, source inventory, collection method, handling limits, hypotheses, known incidents, and reporting audience.

HUMAN RESPONSIBILITIES AND AUTHORITY

The case owner and qualified forensic lead approve scope, collection, access, privacy handling, analysis, disclosure, retention, and release. Counsel or designated authority controls legal strategy. Humans decide material conclusions and whether evidence may be shared.

AI RESPONSIBILITIES AND BOUNDARIES

AI may index authorized copies, summarize records, identify patterns, draft timelines, compare artifacts, and propose follow-up questions. It must preserve source identity, integrity, chain of custody, uncertainty, and privacy boundaries. It must not collect, alter, delete, expose, attribute, or declare evidence authentic without authorized human-controlled procedures.

APPLICABLE EXISTING AGENT ROLES

Forensic Analyst, Incident Responder, Security Auditor, Researcher, Observer, Analyst, Verifier, Governance Reviewer, Legal Advisor, Critic, Documentation Writer, and Memory Curator.

REQUIRED ACTIVITIES

Define authority and question; preserve sources; document volatile state; acquire minimally and reproducibly; hash and seal copies; maintain custody; analyze with validated tools; separate observation from inference; review alternatives; report limitations; retain or dispose under authority.

HUMAN-AI INTERACTION REQUIREMENTS

Show case, source, copy, hash, analyst, method, time, access authority, finding, confidence, and limitation. Require human approval for collection, privacy-sensitive review, attribution, disclosure, retention, and destruction. Never place raw sensitive evidence into an uncontrolled AI context.

ARCHITECTURE AND SYSTEM IMPLICATIONS

Separate source systems, acquisition workspace, evidence store, working copies, analysis, reporting, access audit, legal hold, and disposal. Use immutable or tamper-evident records, least privilege, time synchronization, secure transfer, and reproducible tooling.

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show case state, authority, scope, sources, custody, integrity, analysts, findings, privacy limits, disclosure state, and evidence freshness. Provide authorized preserve, restrict, release, escalate, correct, and close controls with durable audit.

REQUIRED OUTPUTS AND ARTIFACTS

Forensic charter; authority and preservation record; source and custody register; acquisition and integrity record; analysis notes; timeline; findings and alternative explanations; report; disclosure, retention, decision, evidence, and continuity records.

EVIDENCE REQUIREMENTS

Identify source, original state, acquisition method, copy, hash or integrity method, time basis, analyst, tool and version, access, observation, inference, confidence, and limitation. A screenshot, log export, or AI summary is bounded evidence only.

VERIFICATION AND ACCEPTANCE TESTS

Verify authority, preservation, acquisition integrity, custody, time, tool behavior, reproducibility, privacy controls, independent review, report traceability, disclosure, retention, and disposal. Test corrupted copy, missing metadata, conflicting clocks, and tool failure.

FAILURE STATES AND ANTI-PATTERNS

Analyzing originals, undocumented access, broken custody, over-collection, unsupported attribution, altered timestamps, evidence in chat or tickets, and conclusions stated more strongly than the artifacts support.

RECOVERY AND RECONSIDERATION

Quarantine questionable evidence, preserve all known state, document the break, obtain independent review, reacquire where lawful, and downgrade or withdraw affected conclusions. Reassess privacy, legal, safety, and user impact before disclosure or closure.

COMPLETION CRITERIA

Authority, scope, preservation, custody, integrity, analysis, findings, limitations, owners, disclosure, retention, and reopening conditions are explicit. Status remains CONTENT-COMPLETE pending independent verification and owner acceptance.

HANDOFF AND CONTINUITY REQUIREMENTS

Preserve case identity, custody, hashes, methods, findings, decisions, disclosure, legal or privacy holds, and open gaps. Hand off to Incident Response, Legal, Records, Security Operations, Audit, Governance, and affected owners.

RELATED CODEX SECTIONS

004 Evidence and Truth; 018 Risk Management; 206 Security Operations; 214 Incident Response; 219 Legal; 225 Records Management; 226 Audit; 231-254 Testing; 402-404 Review and Postmortem.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

Based on the Canonical Section Contract, shared governance, evidence requirements, security operations, and the integration roadmap. Exact jurisdiction, legal authority, forensic standards, retention, tooling, privacy limits, and acceptance authority remain unresolved.

214

SECTION 214 - INCIDENT RESPONSE

CODEX/03_SECTIONS/214_INCIDENT_RESPONSE.txt

SHA-256 4252f568efa7cdadda2508f87a8810e5ff35a18902db34e5d04f6190cc13064e

6,266 BYTES / PRESERVED SOURCE IDENTITY

SECTION 214 — Incident Response

STATUS: CONTENT-COMPLETE

PURPOSE

Prepare for, detect, analyze, contain, eradicate, recover from, communicate, and learn from incidents affecting security, safety, privacy, service, people, property, or trust.

REQUIRED OUTCOME

An incident-response model with classification, authority, roles, intake, triage, evidence, containment, communication, recovery, legal and privacy coordination, closure, and lessons-learned paths.

WHY THIS MATTERS

Incident response is a time-constrained authority problem as well as a technical process. Delayed escalation, unclear ownership, unsafe containment, lost evidence, or premature closure can increase harm and prevent learning.

APPLICABILITY

Apply when an actual or suspected event may violate security, privacy, safety, availability, policy, law, contract, user trust, or organizational control.

NON-APPLICABILITY CONDITIONS

Record non-applicability only for events with no material consequence, no protected asset or person, and a documented routine handling path that preserves evidence and escalation triggers.

PREREQUISITES AND DEPENDENCIES

Maintain contacts, severity model, authority, playbooks, telemetry, evidence storage, communication paths, legal and privacy guidance, continuity, backup, recovery, and support coverage.

REQUIRED INPUTS

Alert or report, affected assets and people, time, source, scope, severity criteria, evidence, dependencies, responders, authorities, communications, recovery objectives, and known constraints.

HUMAN RESPONSIBILITIES AND AUTHORITY

The incident commander owns coordination and can stop unsafe work. Accountable owners approve containment, service interruption, disclosure, user communication, legal escalation, recovery, and closure. Humans decide material severity, attribution, harm, and residual risk.

AI RESPONSIBILITIES AND BOUNDARIES

AI may correlate authorized signals, summarize timelines, draft hypotheses, identify affected scope, suggest playbook steps, and track actions. It must label evidence, inference, uncertainty, and recommendation; protect sensitive data; and preserve the incident record. It must not declare an incident, contain, delete evidence, notify external parties, attribute, or close without explicit authority and human control.

APPLICABLE EXISTING AGENT ROLES

Incident Responder, Incident Commander, Security Operations Analyst, Forensic Analyst, Researcher, Analyst, Coordinator, Architect, Security Auditor, Governance Reviewer, Legal Advisor, Privacy Reviewer, Tester, Verifier, Documentation Writer, and Memory Curator.

REQUIRED ACTIVITIES

Prepare contacts and exercises; intake and record; validate and classify; preserve evidence; scope impact; contain safely; eradicate or remediate; communicate; recover and monitor; close with owner decision; perform postmortem; track actions and reopening.

HUMAN-AI INTERACTION REQUIREMENTS

Show case, severity, asset, people, evidence, uncertainty, authority, action, impact, and next decision. Require human approval for containment, data access, user or external communication, legal notification, recovery, and closure. Keep manual response and emergency stop paths available.

ARCHITECTURE AND SYSTEM IMPLICATIONS

Separate intake, case record, evidence, analysis, action authority, communication, recovery, and postmortem. Design for degraded telemetry, provider loss, conflicting reports, clock differences, immutable timelines, privacy minimization, and safe rollback.

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show incident state, commander, severity, scope, affected people and assets, evidence freshness, actions, dependencies, communications, decisions, and residual risk. Provide authorized acknowledge, escalate, contain, release, preserve, notify, recover, reopen, and close controls.

REQUIRED OUTPUTS AND ARTIFACTS

Incident charter and severity record; case timeline; evidence and custody record; impact and communication plan; containment and recovery actions; legal and privacy assessment; remediation; postmortem; decisions, exceptions, and continuity record.

EVIDENCE REQUIREMENTS

Identify source, asset, person, event, time basis, method, actor, action, result, confidence, impact, and limitation. Preserve original references and distinguish confirmed, suspected, disproved, and unknown conditions.

VERIFICATION AND ACCEPTANCE TESTS

Exercise intake, classification, paging, command, evidence, containment, communication, legal and privacy escalation, recovery, backup, rollback, user support, and closure. Verify actions are attributable and can be reconstructed from the record.

FAILURE STATES AND ANTI-PATTERNS

Unowned incidents, severity by volume alone, silent scope changes, destructive containment, lost evidence, premature closure, uncoordinated communication, and postmortems that blame people instead of improving controls.

RECOVERY AND RECONSIDERATION

Preserve state and evidence, stabilize affected services, protect people, communicate truthfully, and use approved containment, restore, failover, or manual operation. Reassess harm and residual risk after new evidence. Reopen when impact, scope, root cause, or recovery claim changes.

COMPLETION CRITERIA

Authority, severity, scope, evidence, actions, communications, recovery, owners, residual risk, lessons, and reopening conditions are explicit. Status remains CONTENT-COMPLETE pending independent review and owner acceptance.

HANDOFF AND CONTINUITY REQUIREMENTS

Preserve case identity, timeline, evidence references, decisions, communications, actions, postmortem, remediation, and open gaps. Hand off to Operations, Security, Privacy, Legal, Records, Support, Governance, Testing, and affected owners.

RELATED CODEX SECTIONS

004 Evidence and Truth; 005 Continuity and Recovery; 018 Risk Management; 206 Security Operations; 213 Digital Forensics; 215-218 Fraud, Abuse, Trust, and Privacy; 301-330 Operations; 402-404 Review and Postmortem.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

Based on the Canonical Section Contract, shared governance, evidence and continuity requirements, and the integration roadmap. Exact severity, notification, legal, privacy, staffing, recovery, jurisdiction, and owner acceptance rules remain unresolved.

215

SECTION 215 - FRAUD PREVENTION

CODEX/03_SECTIONS/215_FRAUD_PREVENTION.txt

SHA-256 50f699a34f1127be432c3ee17c9c0da362e4e1d9be61666455e71606b6dd2670

6,269 BYTES / PRESERVED SOURCE IDENTITY

SECTION 215 — Fraud Prevention

STATUS: CONTENT-COMPLETE

PURPOSE

Reduce fraud by identifying deceptive, unauthorized, manipulated, or abusive activity while protecting legitimate users from unjustified suspicion, denial, disclosure, or harm.

REQUIRED OUTCOME

A fraud-prevention model with protected outcomes, threat and abuse scenarios, signals, decision thresholds, human review, user communication, appeal, evidence, privacy, model monitoring, recovery, and accountability.

WHY THIS MATTERS

Fraud controls operate under uncertainty and can shift harm onto innocent people. A score, rule, anomaly, or AI prediction is not proof of fraud; opaque or unreviewable action can create financial, access, reputational, and discriminatory harm.

APPLICABILITY

Apply when systems detect, prevent, investigate, or respond to fraud involving accounts, payments, identity, transactions, content, suppliers, benefits, or organizational resources.

NON-APPLICABILITY CONDITIONS

Record non-applicability when no fraud exposure, transaction, identity, protected outcome, or decision is affected and an approved exact baseline covers the scope. Keep ordinary security and privacy obligations separate.

PREREQUISITES AND DEPENDENCIES

Use identity, authorization, privacy, security operations, threat, payment, legal, ethics, accessibility, support, and incident baselines. Define harm, protected users, decision owner, review, appeal, and notification authority.

REQUIRED INPUTS

Fraud scenarios, assets, transactions, identities, signals, features, rules, models, thresholds, labels, feedback, data sources, user journeys, false-positive cost, review capacity, appeals, and evidence.

HUMAN RESPONSIBILITIES AND AUTHORITY

Owners approve protected outcomes, signals, thresholds, actions, review, appeal, data use, notification, exceptions, and residual risk. Humans review high-impact denials, account closure, financial holds, vulnerable-user impact, and disputed decisions.

AI RESPONSIBILITIES AND BOUNDARIES

AI may analyze authorized signals, identify patterns, draft rules or review queues, and recommend investigation. It must expose features, uncertainty, data quality, drift, and limitations; avoid inferring sensitive traits without authority; and preserve an appeal path. It must not label a person fraudulent, deny service, freeze funds, close an account, or disclose an allegation without delegated authority and human review.

APPLICABLE EXISTING AGENT ROLES

Fraud Analyst, Security Auditor, Researcher, Analyst, Data Scientist, User Experience Reviewer, Privacy Reviewer, Ethics Reviewer, Tester, Verifier, Governance Reviewer, Critic, and Documentation Writer.

REQUIRED ACTIVITIES

Define fraud and harm; map scenarios and users; inventory signals and provenance; design controls and thresholds; assess false positives and disparate impact; route human review; communicate and appeal; monitor drift; investigate; recover victims; test; record decisions and limitations.

HUMAN-AI INTERACTION REQUIREMENTS

Show signal, source, time, threshold, confidence, action, user impact, reviewer, and appeal path. Require human review for high-impact action and allow correction. Do not expose detection logic in a way that enables abuse, but explain decisions sufficiently for fair review.

ARCHITECTURE AND SYSTEM IMPLICATIONS

Separate signal collection, feature processing, decision, enforcement, review, appeal, case evidence, user support, and recovery. Minimize data, protect models and rules, monitor drift and feedback loops, and ensure fail-safe behavior does not permanently deny legitimate users.

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show fraud-control version, affected outcome, signal health, queue, action, uncertainty, false-positive indicators, reviewer, appeals, evidence freshness, and authorized pause, narrow, reverse, notify, and retire controls.

REQUIRED OUTPUTS AND ARTIFACTS

Fraud charter; scenario and signal inventory; decision and review model; privacy and fairness assessment; rules or model documentation; case, appeal, recovery, test, decision, evidence, and continuity records.

EVIDENCE REQUIREMENTS

Identify subject or transaction, signal, source, feature or rule version, time, decision, reviewer, result, confidence, impact, and limitation. A score or pattern proves neither fraud nor justified action.

VERIFICATION AND ACCEPTANCE TESTS

Test fraud and legitimate cases, adversarial adaptation, data drift, false positives, false negatives, missing signals, provider failure, review load, appeal, reversal, accessibility, and notification. Verify independent reproduction and outcome monitoring.

FAILURE STATES AND ANTI-PATTERNS

Score as verdict, opaque denial, sensitive-trait proxy, no appeal, feedback loop, unreviewed account closure, target-chasing metrics, and treating customer friction or complaints as fraud evidence.

RECOVERY AND RECONSIDERATION

Pause or narrow affected controls, preserve evidence, restore legitimate access or funds where appropriate, notify and support affected people, review bias and data quality, and correct downstream records. Reopen on drift, new harm, model or rule change, or disputed outcome.

COMPLETION CRITERIA

Scenarios, outcomes, signals, decisions, owners, review, appeal, privacy, evidence, tests, recovery, limitations, and reopening conditions are explicit. Status remains CONTENT-COMPLETE pending independent verification and owner acceptance.

HANDOFF AND CONTINUITY REQUIREMENTS

CODEX/03_SECTIONS/215_FRAUD_PREVENTION.txt

Preserve rule or model versions, signal provenance, decisions, cases, appeals, corrections, incidents, evidence, exceptions, and open gaps. Hand off to Security, Privacy, Legal, Payments, Support, Data, Testing, Governance, and Operations.

RELATED CODEX SECTIONS

047 Privacy Architecture; 200-202 IAM, Authentication, and Authorization; 206 Security Operations; 208 Threat Modeling; 216 Abuse Prevention; 217 Trust and Safety; 218 Privacy Engineering; 231-254 Testing.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

Based on the Canonical Section Contract, shared governance, security, privacy, ethics, and data context, and the integration roadmap. Exact fraud definitions, data authority, fairness method, legal duties, appeal standard, and acceptance evidence remain unresolved.

216

SECTION 216 - ABUSE PREVENTION

CODEX/03_SECTIONS/216_ABUSE_PREVENTION.txt

SHA-256 a5e51839232900dedb74d13e91797cc2dded60bdd85cd0d25725ecb7073f67fb

6,104 BYTES / PRESERVED SOURCE IDENTITY

SECTION 216 — Abuse Prevention

STATUS: CONTENT-COMPLETE

PURPOSE

Prevent, detect, investigate, and respond to misuse of systems, products, communities, resources, or capabilities while preserving legitimate access, due process, safety, and evidence.

REQUIRED OUTCOME

An abuse-prevention model with abuse taxonomy, affected parties, signals, reporting, triage, user protection, enforcement, appeal, escalation, privacy, evidence, recovery, and continuous review.

WHY THIS MATTERS

Abuse is contextual and often targets people with less power. Overbroad controls can silence legitimate use, expose reporters, or punish victims; weak controls can allow harassment, exploitation, fraud, or unsafe behavior to continue.

APPLICABILITY

Apply when users, operators, suppliers, agents, or external actors can misuse a product, platform, process, facility, data set, or organizational capability to harm people, property, systems, or trust.

NON-APPLICABILITY CONDITIONS

Record non-applicability when no user, public, resource, or trust relationship can be abused within scope and an approved exact baseline documents the conclusion. Do not use absence of reports as proof of absence.

PREREQUISITES AND DEPENDENCIES

Use trust and safety, privacy, security, fraud, legal, ethics, accessibility, support, incident, and governance baselines. Define prohibited harm, reporting authority, vulnerable populations, response, appeal, and emergency escalation.

REQUIRED INPUTS

Abuse taxonomy, user journeys, reports, signals, content or behavior scope, identity and access, risk, policy, reviewer capacity, victim support, evidence, legal duties, and recovery resources.

HUMAN RESPONSIBILITIES AND AUTHORITY

Owners define protected outcomes, prohibited abuse, enforcement, evidence, reporter protection, appeal, emergency response, and residual risk. Trained humans review high-impact action, vulnerable-person cases, ambiguity, and appeals.

AI RESPONSIBILITIES AND BOUNDARIES

AI may classify authorized reports, surface patterns, draft queues and safety explanations, and recommend bounded review. It must preserve context, reporter privacy, uncertainty, cultural and accessibility limits, and appeal. It must not label a person an abuser, expose a reporter, remove content, close an account, or make an emergency determination without delegated human authority.

APPLICABLE EXISTING AGENT ROLES

Trust and Safety Reviewer, User Experience Reviewer, Researcher, Analyst, Security Auditor, Privacy Reviewer, Ethics Reviewer, Incident Responder, Tester, Verifier, Governance Reviewer, Critic, and Documentation Writer.

REQUIRED ACTIVITIES

Define abuse and harm; map affected parties; establish reporting and evidence handling; triage and protect; investigate with proportionality; enforce or remediate; communicate; support victims; provide appeal; monitor evasion and bias; test; review policy and outcomes.

HUMAN-AI INTERACTION REQUIREMENTS

Show report context, source, confidence, policy, action, user impact, reviewer, and appeal. Protect reporters and accused people from unnecessary disclosure. Require human review for irreversible or high-impact action and preserve emergency escalation.

ARCHITECTURE AND SYSTEM IMPLICATIONS

Separate reporting, evidence, classifier or rule, review, enforcement, appeal, support, and audit. Minimize personal data, protect reporter identity, support regional and accessibility needs, and prevent adversarial input from directly causing irreversible action.

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show abuse category, risk, queue, affected parties, evidence freshness, action state, reviewer, policy version, appeals, and authorized protect, restrict, reverse, escalate, notify, and retire controls.

REQUIRED OUTPUTS AND ARTIFACTS

Abuse taxonomy and policy; reporting and triage design; reviewer and victim-support model; enforcement and appeal procedures; privacy and fairness assessment; case, test, decision, evidence, recovery, and continuity records.

EVIDENCE REQUIREMENTS

Identify report, subject, context, source, time, policy, reviewer, action, confidence, impact, and limitation. Reports and model classifications are allegations or signals until reviewed and bounded.

VERIFICATION AND ACCEPTANCE TESTS

Test reporting, privacy, triage, context, false positives, evasion, reviewer load, accessibility, emergency escalation, enforcement, reversal, appeal, victim support, and evidence retention. Verify legitimate use is not systematically blocked.

FAILURE STATES AND ANTI-PATTERNS

Punishing reporters, opaque enforcement, no appeal, context-free classification, proxy discrimination, public accusation, irreversible automation, reviewer burnout, and treating low report volume as low abuse.

RECOVERY AND RECONSIDERATION

Protect affected people, preserve evidence, pause harmful controls, reverse unjustified actions, provide support and appeal, notify owners, and reassess policy or classifier drift. Reopen on new harm, evasion, policy change, or systematic disparity.

COMPLETION CRITERIA

Abuse scope, affected parties, reporting, review, enforcement, appeal, privacy, evidence, recovery, owners, tests, limitations, and reopening conditions are explicit. Status remains CONTENT-COMPLETE pending independent verification and owner acceptance.

HANDOFF AND CONTINUITY REQUIREMENTS

Preserve policy and classifier versions, reports, cases, decisions, appeals, support, evidence, incidents, exceptions, and open gaps with appropriate privacy controls. Hand off to Trust and Safety, Privacy, Security, Legal, Support, Testing, and Governance.

RELATED CODEX SECTIONS

047 Privacy Architecture; 206 Security Operations; 215 Fraud Prevention; 217 Trust and Safety; 218 Privacy Engineering; 219 Legal; 222 Ethics; 231-254 Testing.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

Based on the Canonical Section Contract, shared governance, trust, safety, privacy, and ethics context, and the integration roadmap. Exact abuse taxonomy, jurisdiction, reviewer standard, victim support, appeal, retention, and acceptance evidence remain unresolved.

217

SECTION 217 - TRUST AND SAFETY

CODEX/03_SECTIONS/217_TRUST_AND_SAFETY.txt

SHA-256 1233209e0245727436a14f081a06165f473af8beaedcce1d608f4ad16c85339d

6,158 BYTES / PRESERVED SOURCE IDENTITY

SECTION 217 — Trust and Safety

STATUS: CONTENT-COMPLETE

PURPOSE

Govern the safety, integrity, fairness, reliability, and human impact of products, services, communities, and automated capabilities that people may rely on or be exposed to.

REQUIRED OUTCOME

A trust-and-safety model with harms, affected parties, policies, controls, reporting, review, escalation, transparency, appeal, measurement, incident response, recovery, and accountable ownership.

WHY THIS MATTERS

Trust is earned through dependable behavior, truthful communication, protection from abuse, and meaningful recourse. Safety can fail through foreseeable misuse, opaque automation, inaccessible controls, weak moderation, or metrics that reward activity while hiding harm.

APPLICABILITY

Apply when a product, service, platform, organization, AI capability, or decision process can affect people, public trust, rights, safety, dignity, access, or community conditions.

NON-APPLICABILITY CONDITIONS

Record non-applicability only when the scope has no affected person, public interaction, consequential decision, abuse path, safety impact, or trust claim and an approved exact baseline documents the determination.

PREREQUISITES AND DEPENDENCIES

Use user research, risk, privacy, security, abuse, fraud, legal, ethics, accessibility, incident, governance, and operations baselines. Identify vulnerable groups, harm owners, review authority, appeal, and emergency paths.

REQUIRED INPUTS

Users and affected non-users, intended and foreseeable use, harms, policies, reports, incidents, signals, models, controls, support, accessibility, impact measures, evidence, and unresolved concerns.

HUMAN RESPONSIBILITIES AND AUTHORITY

Owners set protected outcomes, unacceptable harm, policy, enforcement, transparency, appeal, emergency response, and risk acceptance. Humans review high-impact decisions, vulnerable-person impact, material policy changes, and claims made to the public.

AI RESPONSIBILITIES AND BOUNDARIES

AI may summarize authorized reports, identify patterns, draft policy options and tests, and surface uncertainty or conflicting evidence. It must preserve context, privacy, cultural and accessibility boundaries, and human recourse. It must not decide harm, deny rights, remove access, make public claims, or replace accountable review without delegation.

APPLICABLE EXISTING AGENT ROLES

User Experience Reviewer, Trust and Safety Reviewer, Researcher, Analyst, Ethics Reviewer, Privacy Reviewer, Security Auditor, Legal Advisor, Tester, Verifier, Governance Reviewer, Critic, and Documentation Writer.

REQUIRED ACTIVITIES

Identify affected people and harms; define policy and thresholds; design reporting, review, support, appeal, and transparency; assess foreseeable misuse and disparate impact; test controls; monitor outcomes; respond to incidents; communicate; recover; and review policy with evidence and lived experience.

HUMAN-AI INTERACTION REQUIREMENTS

Show affected party, policy, context, evidence, uncertainty, action, reviewer, explanation, and recourse. Require human judgment for high-impact or irreversible action. Preserve accessible reporting, appeal, support, and emergency escalation.

ARCHITECTURE AND SYSTEM IMPLICATIONS

Separate policy, detection, review, enforcement, appeal, support, measurement, incident, and audit. Design for regional context, accessibility, privacy, adversarial behavior, model drift, human workload, and safe degradation. Do not optimize trust metrics as a substitute for safety outcomes.

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show policy version, affected populations, reports, harm signals, reviewer state, appeals, incidents, evidence freshness, and authorized pause, narrow, reverse, notify, escalate, and retire controls.

REQUIRED OUTPUTS AND ARTIFACTS

Trust-and-safety charter; harm and affected-party map; policy and control catalog; review, support, appeal, transparency, and incident design; impact assessment; test, decision, evidence, recovery, and continuity records.

EVIDENCE REQUIREMENTS

Identify claim, affected party, source, context, policy, method, reviewer, result, uncertainty, impact, and limitation. User reports, ratings, model scores, and absence of complaints are bounded signals, not complete safety proof.

VERIFICATION AND ACCEPTANCE TESTS

Test intended and foreseeable misuse, vulnerable-user journeys, reporting, review, appeal, accessibility, false positives, false negatives, evasion, human workload, incident response, reversal, and communication. Verify decisions can be explained and corrected.

FAILURE STATES AND ANTI-PATTERNS

Safety theater, opaque enforcement, no recourse, proxy discrimination, public claims without evidence, optimizing engagement over harm, and treating policy presence as lived safety.

RECOVERY AND RECONSIDERATION

Protect people, pause harmful behavior, preserve evidence, reverse unjustified action, communicate truthfully, provide support and appeal, and reassess controls and policy. Reopen on new harm, population change, model or policy drift, incident, or credible dissent.

COMPLETION CRITERIA

Harms, affected parties, policies, controls, owners, evidence, review, recourse, incidents, recovery, tests, measures, limitations, and reopening conditions are explicit. Status remains CONTENT-COMPLETE pending independent verification and owner acceptance.

HANDOFF AND CONTINUITY REQUIREMENTS

Preserve policy, impact, report, case, appeal, incident, evidence, decision, and exception history with privacy controls. Hand off to Abuse, Fraud, Privacy, Security, Legal, Ethics, Support, UX, Testing, and Governance.

RELATED CODEX SECTIONS

001 Research; 018 Risk Management; 047 Privacy Architecture; 215-218 Fraud, Abuse, Trust, and Privacy; 219 Legal; 222 Ethics; 247 Accessibility Testing; 301-330 Operations; 402-404 Review.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

Based on the Canonical Section Contract, shared governance, user and risk context, and the integration roadmap. Exact harms, populations, policy authority, jurisdiction, transparency, appeal, support, measurement, and acceptance evidence remain unresolved.

218

SECTION 218 - PRIVACY ENGINEERING

CODEX/03_SECTIONS/218_PRIVACY_ENGINEERING.txt

SHA-256 212cd89ed1b534fd1d5821f02f75f4898c2514d8ffc17c020f3147718fa1a99c

6,409 BYTES / PRESERVED SOURCE IDENTITY

SECTION 218 — Privacy Engineering

STATUS: CONTENT-COMPLETE

PURPOSE

Translate privacy expectations, obligations, risks, and human control into data, system, process, interface, and lifecycle design.

REQUIRED OUTCOME

A privacy-engineering model with purpose, data inventory, lawful or authorized basis, minimization, notice, choice, access, correction, retention, deletion, security, sharing, automation, incident, and evidence controls.

WHY THIS MATTERS

Privacy harm can arise even when data is accurate and secure. Excess collection, unexpected reuse, opaque inference, indefinite retention, inaccessible controls, and AI-generated conclusions can remove agency or expose people to decisions they cannot understand or contest.

APPLICABILITY

Apply whenever information can identify, describe, infer about, locate, affect, or be linked to a person, household, device, organization, or protected group.

NON-APPLICABILITY CONDITIONS

Record non-applicability only when no personal, sensitive, linkable, inferred, behavioral, device, or human-impacting information is processed and an approved exact baseline documents the conclusion.

PREREQUISITES AND DEPENDENCIES

Use data, security, identity, user research, legal, regulatory, ethics, accessibility, records, AI, and operations baselines. Identify data owners, subjects, purposes, jurisdictions, processors, transfers, retention, and rights or support authority.

REQUIRED INPUTS

Data inventory and flows, purpose, classification, source, subjects, consent or legal basis, minimization, inference, sharing, access, retention, deletion, security, user controls, incidents, vendors, and unresolved risks.

HUMAN RESPONSIBILITIES AND AUTHORITY

Privacy and data owners approve purpose, collection, reuse, sharing, retention, deletion, rights handling, automated decisions, exceptions, and residual risk. Humans assess meaningful impact, respond to requests, and decide disputed or high-risk processing.

AI RESPONSIBILITIES AND BOUNDARIES

AI may inspect authorized schemas and process descriptions, identify data-flow or minimization gaps, draft notices and tests, and summarize privacy evidence. It must not infer consent, legal basis, identity, sensitivity, or acceptable use from data alone. It must not expose personal data, make a rights decision, repurpose data, or deny a request without human authority and review.

APPLICABLE EXISTING AGENT ROLES

Privacy Engineer, Researcher, Data Architect, Security Auditor, Legal Advisor, Ethics Reviewer, User Experience Reviewer, Analyst, Tester, Verifier, Governance Reviewer, Critic, and Documentation Writer.

REQUIRED ACTIVITIES

Inventory and classify data; define purpose and basis; minimize; map flows and inference; assess harms; design notice, choice, access, correction, deletion, retention, sharing, security, and incident controls; test user journeys; monitor drift; and record decisions and exceptions.

HUMAN-AI INTERACTION REQUIREMENTS

Show data source, purpose, subject, sensitivity, processing, retention, authority, evidence, and limitation. Keep personal data out of unnecessary AI context; require human review for rights, high-impact inference, disclosure, deletion, and policy exceptions. Provide accessible explanations and appeal.

ARCHITECTURE AND SYSTEM IMPLICATIONS

Separate collection, purpose, identity, processing, inference, sharing, storage, access, retention, deletion, audit, and rights services. Minimize and segregate data, enforce purpose and tenant boundaries, support correction and deletion propagation, and make AI inputs and outputs traceable.

OWNER COCKPIT AND USER-CONTROL REQUIREMENTS

Show data classes, purposes, flows, processors, access, retention, consent or authority state, user requests, incidents, evidence freshness, and authorized restrict, correct, export, delete, revoke, and retire controls.

REQUIRED OUTPUTS AND ARTIFACTS

Privacy charter; data inventory and flow; purpose and basis register; impact assessment; minimization, notice, rights, retention, deletion, sharing, security, and AI-processing designs; test, decision, evidence, incident, and continuity records.

EVIDENCE REQUIREMENTS

Identify data, source, subject, purpose, processing, authority, processor, jurisdiction, time, method, result, owner, and limitation. A notice, consent record, deletion log, or privacy scan proves only its declared scope.

VERIFICATION AND ACCEPTANCE TESTS

Verify collection, purpose, minimization, notice, choice, access, correction, deletion, retention, sharing, inference, security, logging, incident, accessibility, and vendor controls. Test stale consent, identity mismatch, deletion failure, model reuse, and cross-boundary transfer.

FAILURE STATES AND ANTI-PATTERNS

Collect first and define purpose later, consent theater, hidden inference, indefinite retention, deletion that leaves replicas, privacy by policy only, inaccessible rights, and personal data placed into uncontrolled AI context.

RECOVERY AND RECONSIDERATION

Stop or restrict processing, preserve required evidence, notify owners and affected people as required, correct or delete unauthorized copies, remediate, and reassess harm and legal duties. Reopen on purpose, population, data, processor, jurisdiction, model, or policy change.

COMPLETION CRITERIA

Data, purpose, authority, subjects, flows, minimization, rights, retention, deletion, security, sharing, owners, evidence, tests, limitations, and reopening conditions are explicit. Status remains CONTENT-COMPLETE pending independent verification and owner acceptance.

HANDOFF AND CONTINUITY REQUIREMENTS

Preserve inventories, purpose and authority decisions, rights records, assessments, incidents, evidence, exceptions, processor changes, and open gaps. Hand off to Data, Security, IAM, Legal, Compliance, Records, AI, Operations, Support, and Governance.

RELATED CODEX SECTIONS

030 Information Architecture; 031 Data Architecture; 047 Privacy Architecture; 200-205 Identity and Protection; 219-225 Legal, Compliance, Policy, Ethics, IP, Licensing, and Records; 391-395 Data Lifecycle.

SOURCE BASIS AND UNRESOLVED SOURCE GAPS

Based on the Canonical Section Contract, shared governance, privacy and data architecture, and the integration roadmap. Exact jurisdiction, lawful or authorized basis, rights, transfer, processor, retention, AI, accessibility, and acceptance requirements remain unresolved.